

CIS VMware ESXi 6.5 Benchmark

v1.0.0 - 11-14-2018

Terms of Use

Please see the below link for our current terms of use:

<https://www.cisecurity.org/cis-securesuite/cis-securesuite-membership-terms-of-use/>

Table of Contents

Terms of Use	1
Overview	7
Intended Audience	7
Consensus Guidance.....	7
Typographical Conventions	8
Scoring Information	8
Profile Definitions	9
Acknowledgements	10
Recommendations	11
1 Install.....	11
1.1 (L1) Ensure ESXi is properly patched (Scored)	11
1.2 (L1) Ensure the Image Profile VIB acceptance level is configured properly (Scored)	13
1.3 (L1) Ensure no unauthorized kernel modules are loaded on the host (Scored)	15
2 Communication	17
2.1 (L1) Ensure NTP time synchronization is configured properly (Scored)	17
2.2 (L1) Ensure the ESXi host firewall is configured to restrict access to services running on the host (Scored)	19
2.3 (L1) Ensure Managed Object Browser (MOB) is disabled (Scored)	21
2.4 (L1) Ensure default self-signed certificate for ESXi communication is not used (Scored)	23
2.5 (L1) Ensure SNMP is configured properly (Not Scored).....	25
2.6 (L1) Ensure dvfilter API is not configured if not used (Scored).....	27
2.7 (L1) Ensure expired and revoked SSL certificates are removed from the ESXi server (Not Scored).....	29
3 Logging	31
3.1 (L1) Ensure a centralized location is configured to collect ESXi host core dumps (Scored)	31
3.2 (L1) Ensure persistent logging is configured for all ESXi hosts (Scored).....	33
3.3 (L1) Ensure remote logging is configured for ESXi hosts (Scored).....	35

4 Access	37
4.1 (L1) Ensure a non-root user account exists for local admin access (Scored) ..	37
4.2 (L1) Ensure passwords are required to be complex (Scored)	39
4.3 (L1) Ensure Active Directory is used for local user authentication (Scored) ..	41
4.4 (L1) Ensure only authorized users and groups belong to the esxAdminsGroup group (Not Scored)	43
4.5 (L1) Ensure the Exception Users list is properly configured (Scored)	45
4.6 (L1) Ensure the maximum failed login attempts is set to 3 (Scored)	47
4.7 (L1) Ensure account lockout is set to 15 minutes (Scored)	49
5 Console	51
5.1 (L1) Ensure the DCUI timeout is set to 600 seconds or less (Scored)	51
5.2 (L2) Ensure DCUI is disabled (Scored)	53
5.3 (L1) Ensure the ESXi shell is disabled (Scored)	55
5.4 (L1) Ensure SSH is disabled (Scored)	57
5.5 (L1) Ensure CIM access is limited (Not Scored)	59
5.6 (L1) Ensure Lockdown mode is enabled (Scored)	61
5.7 (L2) Ensure the SSH authorized_keys file is empty (Scored)	63
5.8 (L1) Ensure idle ESXi shell and SSH sessions time out after 300 seconds or less (Scored)	65
5.9 (L1) Ensure the shell services timeout is set to 1 hour or less (Scored)	67
5.10 (L1) Ensure DCUI has a trusted users list for lockdown mode (Not Scored) ..	69
5.11 (L2) Ensure contents of exposed configuration files have not been modified (Not Scored)	71
6 Storage	73
6.1 (L1) Ensure bidirectional CHAP authentication for iSCSI traffic is enabled (Scored)	73
6.2 (L1) Ensure the uniqueness of CHAP authentication secrets for iSCSI traffic (Not Scored)	75
6.3 (L1) Ensure storage area network (SAN) resources are segregated properly (Not Scored)	77
6.4 (L2) Ensure VMDK files are zeroed out prior to deletion (Not Scored)	79
7 vNetwork	80

7.1 (L1) Ensure the vSwitch Forged Transmits policy is set to reject (Scored)	80
7.2 (L1) Ensure the vSwitch MAC Address Change policy is set to reject (Scored)	82
7.3 (L1) Ensure the vSwitch Promiscuous Mode policy is set to reject (Scored) ..	84
7.4 (L1) Ensure port groups are not configured to the value of the native VLAN (Scored)	86
7.5 (L1) Ensure port groups are not configured to VLAN values reserved by upstream physical switches (Not Scored).....	88
7.6 (L1) Ensure port groups are not configured to VLAN 4095 except for Virtual Guest Tagging (VGT) (Scored)	90
8 Virtual Machines	92
8.1 Communication.....	92
8.1.1 (L1) Ensure informational messages from the VM to the VMX file are limited (Scored)	92
8.1.2 (L2) Ensure only one remote console connection is permitted to a VM at any time (Scored)	94
8.2 Devices	96
8.2.1 (L1) Ensure unnecessary floppy devices are disconnected (Scored).....	96
8.2.2 (L2) Ensure unnecessary CD/DVD devices are disconnected (Scored)	98
8.2.3 (L1) Ensure unnecessary parallel ports are disconnected (Scored).....	100
8.2.4 (L1) Ensure unnecessary serial ports are disconnected (Scored).....	102
8.2.5 (L1) Ensure unnecessary USB devices are disconnected (Scored)	104
8.2.6 (L1) Ensure unauthorized modification and disconnection of devices is disabled (Scored)	106
8.2.7 (L1) Ensure unauthorized connection of devices is disabled (Scored)	108
8.3 Guest.....	110
8.3.1 (L1) Ensure unnecessary or superfluous functions inside VMs are disabled (Not Scored)	110
8.3.2 (L1) Ensure use of the VM console is limited (Not Scored).....	112
8.3.3 (L1) Ensure secure protocols are used for virtual serial port access (Not Scored)	114
8.3.4 (L1) Ensure templates are used whenever possible to deploy VMs (Not Scored)	116

8.4 Monitor.....	118
8.4.1 (L1) Ensure access to VMs through the dvfilter network APIs is configured correctly (Not Scored).....	118
8.4.2 (L1) Ensure VMsafe Agent Address is configured correctly (Not Scored) ..	120
8.4.3 (L1) Ensure VMsafe Agent Port is configured correctly (Not Scored)	122
8.4.4 (L1) Ensure VMsafe Agent is configured correctly (Not Scored)	124
8.4.5 (L2) Ensure Autologon is disabled (Scored)	126
8.4.6 (L2) Ensure BIOS BBS is disabled (Scored)	127
8.4.7 (L2) Ensure Guest Host Interaction Protocol Handler is set to disabled (Scored)	129
8.4.8 (L2) Ensure Unity Taskbar is disabled (Scored).....	131
8.4.9 (L2) Ensure Unity Active is disabled (Scored).....	133
8.4.10 (L2) Ensure Unity Window Contents is disabled (Scored)	135
8.4.11 (L2) Ensure Unity Push Update is disabled (Scored).....	137
8.4.12 (L2) Ensure Drag and Drop Version Get is disabled (Scored)	139
8.4.13 (L2) Ensure Drag and Drop Version Set is disabled (Scored).....	141
8.4.14 (L2) Ensure Shell Action is disabled (Scored).....	143
8.4.15 (L2) Ensure Request Disk Topology is disabled (Scored)	145
8.4.16 (L2) Ensure Trash Folder State is disabled (Scored)	147
8.4.17 (L2) Ensure Guest Host Interaction Tray Icon is disabled (Scored).....	149
8.4.18 (L2) Ensure Unity is disabled (Scored).....	151
8.4.19 (L2) Ensure Unity Interlock is disabled (Scored)	153
8.4.20 (L2) Ensure GetCreds is disabled (Scored)	155
8.4.21 (L2) Ensure Host Guest File System Server is disabled (Scored)	157
8.4.22 (L2) Ensure Guest Host Interaction Launch Menu is disabled (Scored)....	159
8.4.23 (L2) Ensure memSchedFakeSampleStats is disabled (Scored).....	161
8.4.24 (L1) Ensure VM Console Copy operations are disabled (Scored)	163
8.4.25 (L1) Ensure VM Console Drag and Drop operations is disabled (Scored)	165
8.4.26 (L1) Ensure VM Console GUI Options is disabled (Scored)	167
8.4.27 (L1) Ensure VM Console Paste operations are disabled (Scored).....	169
8.4.28 (L1) Ensure access to VM console via VNC protocol is limited (Scored)...	171

8.4.29 (L2) Ensure all but VGA mode on virtual machines is disabled (Not Scored)	173
8.5 Resources	175
8.5.1 (L2) Ensure VM limits are configured correctly (Not Scored)	175
8.5.2 (L2) Ensure hardware-based 3D acceleration is disabled (Scored)	177
8.6 Storage	179
8.6.1 (L1) Ensure nonpersistent disks are limited (Scored)	179
8.6.2 (L1) Ensure virtual disk shrinking is disabled (Scored)	181
8.6.3 (L1) Ensure virtual disk wiping is disabled (Scored)	183
8.7 Tools	184
8.7.1 (L2) Ensure VIX messages from the VM are disabled (Scored)	184
8.7.2 (L1) Ensure the number of VM log files is configured properly (Scored)	185
8.7.3 (L2) Ensure host information is not sent to guests (Scored)	187
8.7.4 (L1) Ensure VM log file size is limited (Scored)	188
Appendix: Summary Table	190
Appendix: Change History	194

Overview

This document provides prescriptive guidance for establishing a secure configuration posture for VMware ESXi 6.5. To obtain the latest version of this guide, please visit <https://www.cisecurity.org/cis-benchmarks/>. If you have questions, comments, or have identified ways to improve this guide, please write us at feedback@cisecurity.org.

Intended Audience

This document is intended for system and application administrators, security specialists, auditors, help desk, and platform deployment personnel who plan to develop, deploy, assess, or secure solutions that incorporate VMware ESXi 6.5.

Consensus Guidance

This benchmark was created using a consensus review process comprised of subject matter experts. Consensus participants provide perspective from a diverse set of backgrounds including consulting, software development, audit and compliance, security research, operations, government, and legal.

Each CIS benchmark undergoes two phases of consensus review. The first phase occurs during initial benchmark development. During this phase, subject matter experts convene to discuss, create, and test working drafts of the benchmark. This discussion occurs until consensus has been reached on benchmark recommendations. The second phase begins after the benchmark has been published. During this phase, all feedback provided by the Internet community is reviewed by the consensus team for incorporation in the benchmark. If you are interested in participating in the consensus process, please visit <https://workbench.cisecurity.org/>.

Typographical Conventions

The following typographical conventions are used throughout this guide:

Convention	Meaning
<code>Stylized Monospace font</code>	Used for blocks of code, command, and script examples. Text should be interpreted exactly as presented.
Monospace font	Used for inline code, commands, or examples. Text should be interpreted exactly as presented.
< <i>italic font in brackets</i> >	Italic texts set in angle brackets denote a variable requiring substitution for a real value.
<i>Italic font</i>	Used to denote the title of a book, article, or other publication.
Note	Additional information or caveats

Scoring Information

A scoring status indicates whether compliance with the given recommendation impacts the assessed target's benchmark score. The following scoring statuses are used in this benchmark:

Scored

Failure to comply with "Scored" recommendations will decrease the final benchmark score. Compliance with "Scored" recommendations will increase the final benchmark score.

Not Scored

Failure to comply with "Not Scored" recommendations will not decrease the final benchmark score. Compliance with "Not Scored" recommendations will not increase the final benchmark score.

Profile Definitions

The following configuration profiles are defined by this Benchmark:

- **Level 1**

Items in this profile intend to:

- be practical and prudent;
- provide a clear security benefit; and
- not inhibit the utility of the technology beyond acceptable means.

- **Level 2**

This profile extends the "Level 1" profile. Items in this profile exhibit one or more of the following characteristics:

- are intended for environments or use cases where security is paramount.
- acts as defense in depth measure.
- may negatively inhibit the utility or performance of the technology.

Acknowledgements

This benchmark exemplifies the great things a community of users, vendors, and subject matter experts can accomplish through consensus collaboration. The CIS community thanks the entire consensus team with special recognition to the following individuals who contributed greatly to the creation of this guide:

The VMware's vSphere 6.5 Security Configuration Guide was an excellent resource in the development of this Benchmark. CIS extends special recognition to the development team of that comprehensive guide. Readers are encouraged to visit <http://vmware.com/go/securityguides> to download VMware's hardening guide and other free security resources made available by VMware.

Editor

Greg Carpenter

Karen Scarfone

Contributor

Pierre Gronau

Recommendations

1 Install

This section contains recommendations for base ESXi install.

1.1 (L1) Ensure ESXi is properly patched (Scored)

Profile Applicability:

- Level 1

Description:

VMware Update Manager is a tool used to automate patch management for vSphere hosts and virtual machines. Creating a baseline for patches is a good way to ensure all hosts are at the same patch level. VMware also publishes advisories on security patches and offers a way to subscribe to email alerts for them.

Rationale:

By staying up to date on ESXi patches, vulnerabilities in the hypervisor can be mitigated. An educated attacker can exploit known vulnerabilities when attempting to attain access or elevate privileges on an ESXi host.

Audit:

Verify that the patches are up to date. The following PowerCLI snippet will provide a list of all installed patches:

```
Foreach ($VMHost in Get-VMHost ) {  
    $ESXCLI = Get-EsxCLI -VMHost $VMHost;  
    (Get-ESXCLI).software.vib.list() | Select-Object  
    @{N="VMHost";E={$VMHost}}, Name, AcceptanceLevel, CreationDate, ID,  
    InstallDate, Status, Vendor, Version;  
}
```

Remediation:

Employ a process to keep ESXi hosts up to date with patches in accordance with industry standards and internal guidelines. Leverage the VMware Update Manager to test and apply patches as they become available.

Impact:

ESXi servers must be in Maintenance Mode to apply patches. This implies all VMs must be moved or powered off on the ESXi server, so the patching process may necessitate having brief outages.

References:

1. https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.update_manager.doc/GUID-EF6BEE4C-4583-4A8C-81B9-5B074CA2E272.html

1.2 (L1) Ensure the Image Profile VIB acceptance level is configured properly (Scored)

Profile Applicability:

- Level 1

Description:

A VIB (vSphere Installation Bundle) is a collection of files that are packaged into an archive. The VIB contains a signature file that is used to verify the level of trust. The ESXi Image Profile supports four VIB acceptance levels:

1. VMware Certified - VIBs created, tested, and signed by VMware
2. VMware Accepted - VIBs created by a VMware partner but tested and signed by VMware
3. Partner Supported - VIBs created, tested, and signed by a certified VMware partner
4. Community Supported - VIBs that have not been tested by VMware or a VMware partner

Rationale:

The ESXi Image Profile should only allow signed VIBs because an unsigned VIB represents untested code installed on an ESXi host. Also, use of unsigned VIBs will cause hypervisor Secure Boot to fail to configure. Community Supported VIBs do not have digital signatures. To protect the security and integrity of your ESXi hosts, do not allow unsigned (CommunitySupported) VIBs to be installed on your hosts.

Audit:

Perform the following to verify unsigned VIBs are not allowed:

1. Connect to each ESX/ESXi host using the ESXi Shell or vCLI, and execute the command "esxcli software acceptance get" to verify the acceptance level is at either "VMware Certified", "VMware Accepted", or "Partner Supported".
2. Connect to each ESX/ESXi host using the vCLI, and execute the command "esxcli software vib list" to verify the acceptance level for each VIB is either "VMware Certified", "VMware Accepted", or "Partner Supported".

Additionally, the following PowerCLI command may be used:

```
# List the Software AcceptanceLevel for each host
Foreach ($VMHost in Get-VMHost ) {
    $ESXCLI = Get-ESXCLI -VMHost $VMHost
```

```

$VMHost | Select Name,
@{N="AcceptanceLevel";E={$ESXCLI.software.acceptance.get()}}
}
# List only the vibs which are not at "VMwareCertified" or "VMwareAccepted"
or "PartnerSupported" acceptance level
Foreach ($VMHost in Get-VMHost ) {
    $ESXCLI = Get-EsxCLI -VMHost $VMHost
    $ESXCLI.software.vib.list() | Where { ($_.AcceptanceLevel -ne
"VMwareCertified") -and ($_.AcceptanceLevel -ne "VMwareAccepted") -and
($_.AcceptanceLevel -ne "PartnerSupported") }
}

```

Remediation:

To implement the recommended configuration state, run the following PowerCLI command (in the example code, the level is Partner Supported):

```

# Set the Software AcceptanceLevel for each host<span>
Foreach ($VMHost in Get-VMHost ) {
    $ESXCLI = Get-EsxCLI -VMHost $VMHost
    $ESXCLI.software.acceptance.Set("PartnerSupported")
}

```

Default Value:

Partner Supported

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.install.doc/GUID-7C9A1E23-7FCD-4295-9CB1-C932F2423C63.html>
2. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-52188148-C579-4F6A-8335-CFBCE0DD2167.html>

CIS Controls:

Version 7

2.2 Ensure Software is Supported by Vendor

Ensure that only software applications or operating systems currently supported by the software's vendor are added to the organization's authorized software inventory. Unsupported software should be tagged as unsupported in the inventory system.

1.3 (L1) Ensure no unauthorized kernel modules are loaded on the host (Scored)

Profile Applicability:

- Level 1

Description:

ESXi hosts by default do not permit the loading of kernel modules that lack valid digital signatures. This feature can be overridden, which would allow unauthorized kernel modules to be loaded.

Rationale:

VMware provides digital signatures for kernel modules. Untested or malicious kernel modules loaded on the ESXi host can put the host at risk for instability and/or exploitation.

Audit:

To list all the loaded kernel modules from the ESXi Shell or vCLI, run: "esxcli system module list". For each module, verify the signature by running: `esxcli system module get -m <module>`.

Additionally, the following PowerCLI command may be used:

```
# List the system modules and Signature Info for each host
Foreach ($VMHost in Get-VMHost ) {
    $ESXCLI = Get-EsxCLI -VMHost $VMHost
    $ESXCLI.system.module.list() | Foreach {
        $ESXCLI.system.module.get($_.Name) | Select @{N="VMHost";E={$VMHost}},
Module, License, Modulefile, Version, SignedStatus, SignatureDigest,
SignatureFingerPrint
    }
}
```

Remediation:

Secure the host by disabling unsigned modules and removing the offending VIBs from the host.

To implement the recommended configuration state, run the following PowerCLI command:

```
# To disable a module:
$ESXCLI = Get-EsxCLI -VMHost "MyHostName_or_IPaddress"
$ESXCLI.system.module.set($false, $false, "MyModuleName")
```


Note: evacuate VMs and place the host into maintenance mode before disabling kernel modules.

References:

1. <http://pubs.vmware.com/vsphere-65/topic/com.vmware.vsphere.security.doc/GUID-E9B71B85-FBA3-447C-8A60-DEE2AE1A405A.html>
2. <http://kb.vmware.com/kb/2042473>

CIS Controls:

Version 7

2.2 Ensure Software is Supported by Vendor

Ensure that only software applications or operating systems currently supported by the software's vendor are added to the organization's authorized software inventory. Unsupported software should be tagged as unsupported in the inventory system.

2 Communication

This section contains recommendations related to ESXi communication.

2.1 (L1) Ensure NTP time synchronization is configured properly (Scored)

Profile Applicability:

- Level 1

Description:

Network Time Protocol (NTP) synchronization should be configured correctly and enabled on each VMware ESXi host to ensure accurate time for system event logs. The time sources used by the ESXi hosts should be in sync with an agreed-upon time standard such as Coordinated Universal Time (UTC). There should be at minimum two NTP sources in place, and they should sync whenever possible.

Rationale:

By ensuring that all systems use the same relative time source (including the relevant localization offset), and that the relative time source can be correlated to an agreed-upon time standard, it is simpler to track and correlate an intruder's actions when reviewing the relevant log files. Incorrect time settings can also make auditing inaccurate.

Audit:

To confirm NTP synchronization is enabled and properly configured, perform the following from the vSphere web client:

1. Select the host.
2. Click "Configure" -> "System" -> "Time Configuration".
3. Click the "Edit..." button.
4. Verify that the names/IP addresses of the NTP servers are correct.
5. Verify that the NTP service startup policy is "Start and stop with host".

Additionally, the following PowerCLI command may be used:

```
# List the NTP Settings for all hosts
Get-VMHost | Select Name, @{N="NTPSetting";E={$_.NTPSetting | Get-VMHostNtpServer}}
```

Remediation:

To enable and properly configure NTP synchronization, perform the following from the vSphere web client:

1. Select the host.
2. Click "Configure" -> "System" -> "Time Configuration".
3. Click the "Edit..." button.
4. Click on "Use Network Time Protocol".
5. Provide the names or IP addresses of your NTP servers. Separate servers with commas.
6. If the NTP Service Status is "Stopped", click on "Start".
7. Change the startup policy to "Start and stop with host".
8. Click "OK".

To implement the recommended configuration state, run the following PowerCLI command:

```
# Set the NTP Settings for all hosts
# If an internal NTP server is used, replace pool.ntp.org with
# the IP address or the Fully Qualified Domain Name (FQDN) of the internal
NTP server
$NTPServers = "pool.ntp.org", "pool2.ntp.org"
Get-VMHost | Add-VmHostNtpServer $NTPServers
```

References:

1. <http://pubs.vmware.com/vsphere-6-5/index.jsp#com.vmware.vcli.examples.doc/GUID-C937B5AA-8413-4791-AA89-C202143B24D5.html>
2. <http://pubs.vmware.com/vsphere-65/topic/com.vmware.vsphere.security.doc/GUID-2553C86E-7981-4F79-B9FC-A6CECA52F6CC.html>

CIS Controls:

Version 7

6.1 Utilize Three Synchronized Time Sources

Use at least three synchronized time sources from which all servers and network devices retrieve time information on a regular basis so that timestamps in logs are consistent.

2.2 (L1) Ensure the ESXi host firewall is configured to restrict access to services running on the host (Scored)

Profile Applicability:

- Level 1

Description:

The ESXi firewall is enabled by default and allows ping (ICMP) and communication with DHCP/DNS clients. Access to services should only be allowed by authorized IP addresses/networks.

Rationale:

Unrestricted access to services running on an ESXi host can expose a host to outside attacks and unauthorized access. Reduce the risk by configuring the ESXi firewall to only allow access from authorized IP addresses and networks.

Audit:

To confirm access to services running on an ESXi host is properly restricted, perform the following from the vSphere web client:

1. Select the host.
2. Go to "Configure" -> "System" -> "Security Profile".
3. In the "Firewall" section, select "Edit...".
4. For each enabled service, (e.g., ssh, vSphere Web Access, http client) check to see if the specified allowed IP addresses are correct.

Additionally, the following PowerCLI command may be used:

```
# List all services for a host
Get-VMHost HOST1 | Get-VMHostService
# List the services which are enabled and have rules defined for specific IP
ranges to access the service
Get-VMHost HOST1 | Get-VMHostFirewallException | Where {$_.Enabled -and (-not
$_ .ExtensionData.AllowedHosts.AllIP)}
# List the services which are enabled and do not have rules defined for
specific IP ranges to access the service
Get-VMHost HOST1 | Get-VMHostFirewallException | Where {$_.Enabled -and
($_ .ExtensionData.AllowedHosts.AllIP)}
```

Remediation:

To properly restrict access to services running on an ESXi host, perform the following from the vSphere web client:

1. Select the host.
2. Go to "Configure" -> "System" -> "Security Profile".
3. In the "Firewall" section, select "Edit...".
4. For each enabled service, (e.g., ssh, vSphere Web Access, http client) provide the range of allowed IP addresses.
5. Click "OK".

References:

1. <http://pubs.vmware.com/vsphere-65/topic/com.vmware.vsphere.security.doc/GUID-8912DD42-C6EA-4299-9B10-5F3AEA52C605.html>

CIS Controls:

Version 7

9.4 Apply Host-based Firewalls or Port Filtering

Apply host-based firewalls or port filtering tools on end systems, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.

2.3 (L1) Ensure Managed Object Browser (MOB) is disabled (Scored)

Profile Applicability:

- Level 1

Description:

The Managed Object Browser (MOB) is a web-based server application that lets you examine objects that exist on the server side, explore the object model used by the VM kernel to manage the host, and change configurations. It is installed and started automatically when vCenter is installed.

Rationale:

The MOB is meant to be used primarily for debugging the vSphere SDK. Because there are no access controls, the MOB could also be used as a method to obtain information about a host being targeted for unauthorized access.

Audit:

To determine if the MOB is enabled, run the following command from the ESXi shell:

```
vim-cmd proxysvc/service_list
```

Additionally, the following PowerCLI command may be used:

```
Get-VMHost | Get-AdvancedSetting -Name  
Config.HostAgent.plugins.solo.enableMob
```

Remediation:

To disable the MOB, run the following ESXi shell command:

```
vim-cmd proxysvc/remove_service "/mob" "httpsWithRedirect"
```

Additionally, the following PowerCLI command may be used:

```
Get-VMHost | Get-AdvancedSetting -Name  
Config.HostAgent.plugins.solo.enableMob | Set-AdvancedSetting -value "false"
```

Note: You cannot disable the MOB while a host is in lockdown mode.

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-0EF83EA7-277C-400B-B697-04BDC9173EA3.html>

CIS Controls:

Version 6

9.2 Leverage Host-based Firewalls

Apply host-based firewalls or port filtering tools on end systems, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.

2.4 (L1) Ensure default self-signed certificate for ESXi communication is not used (Scored)

Profile Applicability:

- Level 1

Description:

The default certificate is self-signed, not signed by a trusted certificate authority (CA). It should be replaced with a valid certificate issued by a trusted CA.

Rationale:

Using the default self-signed certificate may increase risk related to man-in-the-middle (MITM) attacks.

Audit:

View the details of the SSL certificate presented by the ESXi host and determine if it is issued by a trusted CA:

1. Log in to the ESXi Shell, either directly from the DCUI or from an SSH client, as a user with administrator privileges.
2. In the directory `/etc/vmware/ssl`, rename the existing certificates using the following commands:

```
mv rui.crt orig.rui.crt  
mv rui.key orig.rui.key
```

3. Copy the certificates you want to use to `/etc/vmware/ssl`.
4. Rename the new certificate and key to `rui.crt` and `rui.key`.
5. Restart the host after you install the new certificate.

Alternatively, you can put the host into maintenance mode, install the new certificate, use the Direct Console User Interface (DCUI) to restart the management agents, and set the host to exit maintenance mode.

Remediation:

Leverage VMware's SSL Certificate Automation Tool to install CA-signed SSL certificates. For more information on this tool, please see <http://kb.vmware.com/kb/2057340>.

Impact:

Replacing the default certificate might cause vCenter Server to stop managing the host. Disconnect and reconnect the host if vCenter Server cannot verify the new certificate.

References:

1. <https://kb.vmware.com/s/article/2111219>
2. <http://pubs.vmware.com/vsphere-65/topic/com.vmware.vsphere.security.doc/GUID-AC7E6DD7-F984-4E0F-983A-463031BA5FE7.html>

2.5 (L1) Ensure SNMP is configured properly (Not Scored)

Profile Applicability:

- Level 1

Description:

Simple Network Management Protocol (SNMP) can be used to help manage hosts. Many organizations have other means in place of managing hosts and do not need SNMP enabled. If SNMP is needed, it should be configured properly to reduce the risk of misuse or compromise. For example, ESXi supports SNMPv3, which provides stronger security than SNMPv1 or SNMPv2, including key authentication and encryption. It is also important to configure the destination for SNMP traps.

Rationale:

If SNMP is not properly configured, monitoring data containing sensitive information can be sent to a malicious host and used to help exploit the host.

Audit:

To confirm the proper configuration of SNMP, perform the following from the ESXi Shell or vCLI:

1. Run the following to determine if SNMP is being used:

```
esxcli system snmp get
```

2. If SNMP is being used, refer to the vSphere Monitoring and Performance guide, chapter 8 for steps to verify the parameters.

Additionally, the following PowerCLI command may be used to view the SNMP configuration:

```
# List the SNMP Configuration of a host (single host connection required)
Get-VMHostSnmp
```

Remediation:

To correct the SNMP configuration, perform the following from the ESXi Shell or vCLI:

1. If SNMP is not needed, disable it by running:

```
esxcli system snmp set --enable false
```

2. If SNMP is needed, refer to the vSphere Monitoring and Performance guide, chapter 8 for steps to configure it.

Additionally, the following PowerCLI command may be used to implement the configuration:

```
# Update the host SNMP Configuration (single host connection required)
Get-VMHostSNMP | Set-VMHostSNMP -Enabled:$true -ReadOnlyCommunity '<secret>'
```

Notes:

- SNMP must be configured on each ESXi host
- SNMP settings can be configured using Host Profiles

References:

1. <http://pubs.vmware.com/vsphere-65/topic/com.vmware.vsphere.monitoring.doc/GUID-8EF36D7D-59B6-4C74-B1AA-4A9D18AB6250.html>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

2.6 (L1) Ensure dvfilter API is not configured if not used (Scored)

Profile Applicability:

- Level 1

Description:

The dvfilter network API is used by some products (e.g., VMSafe). If it is not in use, it should not be configured to send network information to a VM.

Rationale:

If the dvfilter network API is enabled in the future and it is already configured, an attacker might attempt to connect a VM to it, thereby potentially providing access to the network of other VMs on the host.

Audit:

If the dvfilter network API is not being used on the host, ensure that the following kernel parameter has a blank value: `Net.DVFilterBindIpAddress`.

1. From the vSphere web client, select the host and click "Configure" -> "System" -> "Advanced System Settings".
2. Enter `Net.DVFilterBindIpAddress` in the filter.
3. Verify `Net.DVFilterBindIpAddress` has an empty value.
4. If an appliance is being used, then make sure the value of this parameter is set to the proper IP address.

Additionally, the following PowerCLI command may be used to verify the setting:

```
# List Net.DVFilterBindIpAddress for each host
Get-VMHost | Select Name, @{N="Net.DVFilterBindIpAddress";E={$_.Get-AdvancedSetting Net.DVFilterBindIpAddress | Select -ExpandProperty Values}}
```

Remediation:

To remove the configuration for the dvfilter network API, perform the following from the vSphere web client:

1. Select the host and click "Configure" -> "System" -> "Advanced System Settings".
2. Enter `Net.DVFilterBindIpAddress` in the filter.
3. Set `Net.DVFilterBindIpAddress` to an empty value.
4. If an appliance is being used, make sure the value of this parameter is set to the proper IP address.

5. Make sure the attribute is highlighted, then click the pencil icon.
6. Enter the proper IP address.
7. Click "OK".

To implement the recommended configuration state, run the following PowerCLI command:

```
# Set Net.DVFilterBindIpAddress to null on all hosts
Get-VMHost HOST1 | Foreach { Set-AdvancedSetting -VMHost $_ -Name
Net.DVFilterBindIpAddress -IPValue "" }
```

Impact:

This will prevent a dvfilter-based network security appliance such as a firewall from functioning if not configured correctly.

Default Value:

Not configured

References:

1. <http://pubs.vmware.com/vsphere-65/topic/com.vmware.vsphere.security.doc/GUID-CD0783C9-1734-4B9A-B821-ED17A77B0206.html>
2. http://pubs.vmware.com/vsphere-65/topic/com.vmware.vsphere.ext_solutions.doc/GUID-6013E15D-92CE-4970-953C-ACCB36ADA8AD.html

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

2.7 (L1) Ensure expired and revoked SSL certificates are removed from the ESXi server (Not Scored)

Profile Applicability:

- Level 1

Description:

By default, ESXi hosts do not have Certificate Revocation List (CRL) checking available, so expired and revoked SSL certificates must be checked and removed manually.

Rationale:

Leaving expired and revoked certificates on your vCenter Server system can compromise your environment. Replacing certificates will avoid having users get used to clicking through browser warnings. The warning might be an indication of a man-in-the-middle attack, and only inspection of the certificate and thumbprint can guard against such attacks.

Audit:

To assess if there are expired or revoked SSL certificates on your ESXi server, use the PowerCLI script called out in "[verify-ssl-certificates](#)".

Remediation:

Replace expired and revoked certificates with certificates from a trusted CA. Certificates can be replaced in a number of ways:

Replace a Default ESXi Certificate and Key from the ESXi Shell

1. Log in to the ESXi Shell, either directly from the DCUI or from an SSH client, as a user with administrator privileges.
2. In the directory /etc/vmware/ssl, rename the existing certificates using the following commands:

```
mv rui.crt orig.rui.crt  
mv rui.key orig.rui.key
```

3. Copy the certificates that you want to use to /etc/vmware/ssl.
4. Rename the new certificate and key to rui.crt and rui.key.
5. Restart the host after you install the new certificate.

Alternatively, you can put the host into maintenance mode, install the new certificate, use the Direct Console User Interface (DCUI) to restart the management agents, and set the

host to exit maintenance mode.

Replace a Default ESI Certificate and Key by Using the vifs Command

1. Back up the existing certificates.
2. Generate a certificate request following the instructions from the certificate authority.
3. At the command line, use the vifs command to upload the certificate to the appropriate location on the host.

```
vifs --server hostname --username username --put rui.crt /host/ssl_cert  
vifs --server hostname --username username --put rui.key /host/ssl_key
```

4. Restart the host.

Alternatively, you can put the host into maintenance mode, install the new certificate, and then use the Direct Console User Interface (DCUI) to restart the management agents.

Replace A Default ESI Certificate and Key Using HTTP PUT

1. Back up the existing certificates.
2. In your upload application, process each file as follows:
3. Open the file.
4. Publish the file to one of these locations:

```
Certificates https://hostname/host/ssl_cert  
Keys https://hostname/host/ssl_key
```

3. The locations /host/ssl_cert and host/ssl_key link to the certificate files in /etc/vmware/ssl.
4. Restart the host.

References:

1. <http://pubs.vmware.com/vsphere-65/topic/com.vmware.vsphere.security.doc/GUID-AC7E6DD7-F984-4E0F-983A-463031BA5FE7.html>
2. <http://en-us.sysadmins.lv/Lists/Posts/Post.aspx?List=332991f0-bfed-4143-9eea-f521167d287c&ID=60>

3 Logging

This section contains recommendations related to ESXi's logging capabilities.

3.1 (L1) Ensure a centralized location is configured to collect ESXi host core dumps (Scored)

Profile Applicability:

- Level 1

Description:

The VMware vSphere Network Dump Collector service allows for collecting diagnostic information from a host that experiences a critical fault. This service provides a centralized location for collecting ESXi host core dumps.

Rationale:

When a host crashes, an analysis of the resultant core dump is essential to being able to identify the cause of the crash and determine a resolution. Installing a centralized dump collector helps ensure that core files are successfully saved and made available in the event an ESXi host should ever panic.

Audit:

Run the following ESXi shell command to determine if the host is configured as prescribed:

```
esxcli system coredump network get
```

Remediation:

To implement the recommended configuration state, run the following ESXi shell commands:

```
# Configure remote Dump Collector Server
esxcli system coredump network set -v [VMK#] -i [DUMP_SERVER] -o [PORT]
# Enable remote Dump Collector
esxcli system coredump network set -e true
```

References:

1. <http://kb.vmware.com/kb/1032051>

2. http://pubs.vmware.com/vsphere-6-5/index.jsp?topic=%2Fcom.vmware.vcli.examples.doc%2Fcli_performance.12.4.html
3. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.install.doc/GUID-775F602C-7432-4259-B132-4EC1F38A7EE7.html>
4. <http://www.youtube.com/watch?v=veE6M7Na8-A>

CIS Controls:

Version 7

6.5 Central Log Management

Ensure that appropriate logs are being aggregated to a central log management system for analysis and review.

3.2 (L1) Ensure persistent logging is configured for all ESXi hosts (Scored)

Profile Applicability:

- Level 1

Description:

ESXi can be configured to store log files on an in-memory file system. This occurs when the host's `Syslog.global.LogDir` property is set to a non-persistent location, such as `/scratch`. When this is done, only a single day's worth of logs are stored at any time. Additionally, log files will be reinitialized upon each reboot.

Rationale:

Non-persistent logging presents a security risk because user activity logged on the host is only stored temporarily and will not be preserved across reboots. This can also complicate auditing and make it harder to monitor events and diagnose issues. ESXi host logging should always be configured to a persistent datastore.

Audit:

To verify persistent logging is configured properly, perform the following from the vSphere web client:

1. Select the host and go to "Configure" -> "System" -> "Advanced System Settings".
2. Enter `Syslog.global.LogDir` in the filter.
3. Ensure `Syslog.global.LogDir` is not set to `/scratch` or any other non-persistent datastore.

Alternatively, the following PowerCLI command may be used:

```
# List Syslog.global.logDir for each host
Get-VMHost | Select Name, @{N="Syslog.global.logDir";E={$_.Get-
AdvancedConfiguration Syslog.global.logDir | Select -ExpandProperty Values}}
```

Remediation:

To configure persistent logging properly, perform the following from the vSphere web client:

1. Select the host and go to "Configure" -> "System" -> "Advanced System Settings".
2. Enter `Syslog.global.LogDir` in the filter.
3. Set the `Syslog.global.LogDir` to the desired datastore path. Note: additional disk space may be required to store the log files.

4. Make sure the attribute is highlighted, then click the pencil icon.

Alternatively, run the following PowerCLI command:

```
# Set Syslog.global.logDir for each host
Get-VMHost | Foreach { Set-AdvancedConfiguration -VMHost $_ -Name
Syslog.global.logDir -Value "<NewLocation>" }
```

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-9F67DB52-F469-451F-B6C8-DAE8D95976E7.html>
2. <http://kb.vmware.com/kb/1033696>

CIS Controls:

Version 7

6.2 Activate audit logging

Ensure that local logging has been enabled on all systems and networking devices.

6.3 Enable Detailed Logging

Enable system logging to include detailed information such as a event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.

3.3 (L1) Ensure remote logging is configured for ESXi hosts (Scored)

Profile Applicability:

- Level 1

Description:

By default, ESXi logs are stored on a local scratch volume or ramdisk. To preserve logs, also configure remote logging to a central log host for the ESXi hosts.

Rationale:

Remote logging to a central log host provides a secure, centralized store for ESXi logs. You can more easily monitor all hosts with a single tool. You can also do aggregate analysis and searching to look for such things as coordinated attacks on multiple hosts. Logging to a secure, centralized log server helps prevent log tampering and provides a long-term audit record.

Audit:

To ensure remote logging is configured properly, perform the following from the vSphere web client:

1. Select the host and click "Configure" -> "System" -> "Advanced System Settings".
2. Enter `Syslog.global.logHost` in the filter.
3. Verify the `Syslog.global.logHost` is set to the hostname of the central log server.

Alternately, the following PowerCLI command may be used:

```
# List Syslog.global.logHost for each host
Get-VMHost | Select Name, @{N="Syslog.global.logHost";E={$_.Get-AdvancedSetting Syslog.global.logHost}}
```

Remediation:

To configure remote logging properly, perform the following from the vSphere web client:

1. Select the host and click "Configure" -> "System" -> "Advanced System Settings".
2. Enter `Syslog.global.logHost` in the filter.
3. Make sure `Syslog.global.logHost` is highlighted, then click the pencil icon.
4. Set `Syslog.global.logHost` to the hostname or IP address of the central log server.
5. Click "OK".

Alternately, run the following PowerCLI command:

```
# Set Syslog.global.logHost for each host
Get-VMHost | Foreach { Set-AdvancedSetting -VMHost $_ -
Name Syslog.global.logHost -Value "<NewLocation>" }
```

Note: When setting a remote log host, it is also recommended to set the "Syslog.global.logDirUnique" to true. You must configure the syslog settings for each host.

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-9F67DB52-F469-451F-B6C8-DAE8D95976E7.html>
2. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.install.doc/GUID-775F602C-7432-4259-B132-4EC1F38A7EE7.html>

CIS Controls:

Version 7

6.2 Activate audit logging

Ensure that local logging has been enabled on all systems and networking devices.

6.3 Enable Detailed Logging

Enable system logging to include detailed information such as a event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.

4 Access

This section contains recommendations related to ESXi access management.

4.1 (L1) *Ensure a non-root user account exists for local admin access* (Scored)

Profile Applicability:

- Level 1

Description:

By default, each ESXi host has a single "root" admin account that is used for local administration and to connect the host to vCenter Server. Use of this shared account should be limited, and named (non-root) user accounts with admin privileges should be used instead.

Rationale:

To avoid sharing a common root account, it is recommended on each host to create at least one named user account and assign it full admin privileges, and to use this account in lieu of a shared "root" account. Limit the use of "root", including setting a highly complex password for the account, but do not remove the "root" account.

Audit:

To confirm one or more named user accounts have been established, perform the following for each ESXi host:

1. Connect directly to the ESXi host using the vSphere Client.
2. Login as root or another authorized user.
3. Select Manage, then select the Security & Users tab.
4. Select User and view the local users.
5. Ensure at least one user exists that possesses the following:
6. The user has been granted shell access.
7. Select the "Permissions" tab and verify the "Administrator" role has been granted to the user.

Remediation:

To create one or more named user accounts (local ESXi user accounts), perform the following using the vSphere client (not the vSphere web client) for each ESXi host:

1. Connect directly to the ESXi host using the vSphere Client.
2. Login as root.
3. Select Manage, then select the Security & Users tab.
4. Select User and view the local users.
5. Add a local user and grant shell access to this user.
6. Select the Host, then select "Actions" and "Permissions".
7. Assign the "Administrator" role to the user.

Notes:

1. Even if you add your ESXi host to an Active Directory domain, it is still recommended to add at least one local user account to ensure admins can still login in the event the host ever becomes isolated and unable to access Active Directory.
2. Adding local user accounts can be automated using Host Profiles.

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.html.hostclient.doc/GUID-0898677F-CE98-41FB-A488-29DF6210CF5D.html>

CIS Controls:

Version 7

4.3 Ensure the Use of Dedicated Administrative Accounts

Ensure that all users with administrative account access use a dedicated or secondary account for elevated activities. This account should only be used for administrative activities and not internet browsing, email, or similar activities.

4.2 (L1) Ensure passwords are required to be complex (Scored)

Profile Applicability:

- Level 1

Description:

ESXi uses the `pam_passwdqc.so` plug-in to set password strength and complexity. Options include setting minimum password length, requiring password characters to come from particular character sets, and restricting the number of consecutive failed logon attempts permitted. The settings should enforce the organization's password policies.

Note that an uppercase character that begins a password does not count toward the number of character classes used, and neither does a number that ends a password.

Rationale:

All passwords for ESXi hosts should be hard to guess to reduce the risk of unauthorized access.

Note: ESXi imposes no restrictions on the root password. Password strength and complexity rules only apply to non-root users.

Audit:

To confirm password complexity requirements are set, perform the following:

1. Login to the ESXi shell as a user with administrator privileges.
2. Open `/etc/pam.d/passwd`.
3. Locate the following line:

```
password requisite /lib/security/$ISA/pam_passwdqc.so retry=N  
min=N0,N1,N2,N3,N4
```

4. Confirm N is less than or equal to 5.
5. Confirm N0 is set to `disabled`.
6. Confirm N1 is set to `disabled`.
7. Confirm N2 is set to `disabled`.
8. Confirm N3 is set to `disabled`.
9. Confirm N4 is set to 14 or greater.

The above requires all passwords to be 14 or more characters long and comprised of at least one character from four distinct character sets. Additionally, a maximum of 5 consecutive failed login attempts are permitted.

Remediation:

To set the password complexity requirements, perform the following:

1. Login to the ESXi shell as a user with administrator privileges.
2. Open `/etc./pam.d/passwd`.
3. Locate the following line:

```
password requisite /lib/security/$ISA/pam_passwdqc.so retry=N  
min=N0,N1,N2,N3,N4
```

4. Set N to less than or equal to 5.
5. Set N0 to disabled.
6. Set N1 to disabled.
7. Set N2 to disabled.
8. Set N3 to disabled.
9. Set N4 to 14 or greater.

The above requires all passwords to be 14 or more characters long and comprised of at least one character from four distinct character sets. Additionally, a maximum of 5 consecutive failed login attempts are permitted.

References:

1. <http://pubs.vmware.com/vsphere-60/topic/com.vmware.vsphere.hostclient.doc/GUID-2DA83B47-86E5-4BE3-920E-C2504400102E.html>
2. <http://www.openwall.com/passwdqc/README.shtml>
3. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-DC96FFDB-F5F2-43EC-8C73-05ACDAE6BE43.html>

CIS Controls:

Version 7

4.4 Use Unique Passwords

Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.

4.3 (L1) Ensure Active Directory is used for local user authentication (Scored)

Profile Applicability:

- Level 1

Description:

ESXi can be configured to use a directory service such as Active Directory to manage users and groups. It is recommended that a directory service be used.

Note: If the AD group "ESX Admins" (default) is created, all users and groups that are members of this group will have full administrative access to all ESXi hosts in the domain.

Rationale:

Joining ESXi hosts to an Active Directory (AD) domain eliminates the need to create and maintain multiple local user accounts. Using AD for user authentication simplifies the ESXi host configuration, ensures password complexity and reuse policies are enforced, and reduces the risk of security breaches and unauthorized access.

Audit:

To confirm AD is used for local user authentication, perform the following from the vSphere Web Client:

1. Select the host and go to "Manage" -> "Security & Users" -> "Authentication".
2. Ensure the domain settings are in accordance with the user credentials for an AD user that has the rights to join computers to the domain.

Alternately, execute the following PowerCLI command:

```
# Check each host and their domain membership status
Get-VMHost | Get-VMHostAuthentication | Select VmHost, Domain,
DomainMembershipStatus
```

Remediation:

To use AD for local user authentication, perform the following from the vSphere Web Client:

1. Select the host and go to "Manage" -> "Security & Users" -> "Authentication".
2. Click the "Join Domain" button.

3. Provide the domain name along with the user credentials for an AD user that has the rights to join computers to the domain.
4. Click "OK".

Alternately, run the following PowerCLI command:

```
# Join the ESXI Host to the Domain
Get-VMHost HOST1 | Get-VMHostAuthentication | Set-VMHostAuthentication -
Domain domain.local -User Administrator -Password Passw0rd -JoinDomain
```

Notes:

1. Host Profiles can be used to automate adding hosts to an AD domain.
2. Consider using the vSphere Authentication proxy to avoid transmitting AD credentials over the network.

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.0/com.vmware.vsphere.security.doc/GUID-63D22519-38CC-4A9F-AE85-97A53CB0948A.html>

CIS Controls:

Version 7

16.2 Configure Centralized Point of Authentication

Configure access for all accounts through as few centralized points of authentication as possible, including network, security, and cloud systems.

4.4 (L1) Ensure only authorized users and groups belong to the *esxAdminsGroup* group (Not Scored)

Profile Applicability:

- Level 1

Description:

The AD group used by vSphere is defined by the `esxAdminsGroup` attribute. By default, this attribute is set to "ESX Admins". All members of the group are granted full administrative access to all ESXi hosts in the domain. Monitor AD for the creation of this group, and limit membership to highly trusted users and groups.

Rationale:

An unauthorized user or group having membership in the `esxAdminsGroup` group will have full administrative access to all ESXi hosts. Such users may compromise the confidentiality, availability, and integrity of the all ESXi hosts and the respective data and processes they influence.

Audit:

To verify only authorized users and groups belong to `esxAdminsGroup`, go to Active Directory and review the membership of the group name that is defined by the advanced host setting: `Config.HostAgent.plugins.hostsvc.esxAdminsGroup`.

Remediation:

To remove unauthorized users and groups belonging to `esxAdminsGroup`, perform the following steps after coordination between vSphere admins and Active Directory admins:

1. Verify the setting of the `esxAdminsGroup` attribute.
2. View the list of members for that Microsoft Active Directory group.
3. Remove all unauthorized users and groups from that group.

If full admin access for the AD ESX admins group is not desired, you can disable this behavior using the advanced host setting:

`"Config.HostAgent.plugins.hostsvc.esxAdminsGroupAutoAdd"`.

Default Value:

"ESX Admins"

References:

1. <http://pubs.vmware.com/vsphere-60/topic/com.vmware.wssdk.apiref.doc/vim.host.AuthenticationManager.html>

CIS Controls:

Version 7

4.1 Maintain Inventory of Administrative Accounts

Use automated tools to inventory all administrative accounts, including domain and local accounts, to ensure that only authorized individuals have elevated privileges.

4.5 (L1) Ensure the Exception Users list is properly configured (Scored)

Profile Applicability:

- Level 1

Description:

Users who are added to the "Exception Users" list do not lose their permissions when the host enters lockdown mode. Usually you may want to add some service accounts, such as a backup agent, to the Exception Users list.

Rationale:

Users who do not require special permissions should not be exempted from lockdown mode because this increases the risk of unauthorized actions being performed, especially if a user account is compromised.

Audit:

To verify the membership of the "Exception Users" list, perform the following:

1. From the vSphere web client, select the host.
2. Click on "Configure" -> "Settings" -> "System" -> "Security Profile".
3. Scroll down to "Lockdown Mode".
4. Verify that the list of "Exception Users" is correct.

Remediation:

To correct the membership of the "Exception Users" list, perform the following:

1. From the vSphere web client, select host.
2. Click on "Configure" -> "Settings" -> "System" -> "Security Profile".
3. Scroll down to "Lockdown Mode".
4. Click "Edit", then click on "Exception Users".
5. Add or delete users as per your organization's requirements.

References:

1. <https://blogs.vmware.com/vsphere/2015/03/vsphere-6-0-lockdown-mode-exception-users.html>

CIS Controls:

Version 7

16 Account Monitoring and Control
Account Monitoring and Control

4.6 (L1) Ensure the maximum failed login attempts is set to 3 (Scored)

Profile Applicability:

- Level 1

Description:

Authentication should be configured so there is a maximum number of consecutive failed login attempts for each account, at which point the account at risk will be locked out.

Rationale:

Multiple account login failures for the same account could possibly be an attacker trying to brute force guess the password.

Audit:

To verify the maximum failed login attempts is set properly, perform the following steps:

1. From the vSphere Web Client, select the host.
2. Click "Configure" -> "Settings" -> "System" -> "Advanced System Settings".
3. Enter "Security.AccountLockFailures" in the filter.
4. Verify that the value for this parameter is 3.

Alternately, the following PowerCLI command may be used:

```
Get-VMHost | Get-AdvancedSetting -Name Security.AccountLockFailures
```

Remediation:

To set the maximum failed login attempts correctly, perform the following steps:

1. From the vSphere Web Client, select the host.
2. Click "Configure" -> "Settings" -> "System" -> "Advanced System Settings".
3. Enter "Security.AccountLockFailures" in the filter.
4. Click "Edit".
5. Set the value for this parameter to 3.

Alternately, use the following PowerCLI command:

```
Get-VMHost | Get-AdvancedSetting -Name Security.AccountLockFailures | Set-AdvancedSetting -Value 3
```


References:

1. <https://code.vmware.com/apis/196/vsphere#https://vdc-repo.vmware.com/vmwb-repository/dcr-public/6b586ed2-655c-49d9-9029-bc416323cb22/fa0b429a-a695-4c11-b7d2-2cbc284049dc/doc/vim.option.OptionManager.html>

CIS Controls:

Version 7

16 Account Monitoring and Control
Account Monitoring and Control

4.7 (L1) Ensure account lockout is set to 15 minutes (Scored)

Profile Applicability:

- Level 1

Description:

An account is automatically locked after the maximum number of failed consecutive login attempts is reached. The account should be automatically unlocked after 15 minutes, otherwise administrators will need to manually unlock accounts on request by authorized users.

Rationale:

This setting reduces the inconvenience for benign users and the overhead on administrators, while also severely slowing down any brute force password guessing attacks.

Audit:

To verify the account lockout is set to 15 minutes, perform the following:

1. From the vSphere Web Client, select the host.
2. Click "Configure" -> "Settings" -> "System" -> "Advanced System Settings".
3. Enter "Security.AccountUnlockTime" in the filter.
4. Verify that the value for this parameter is set to 900.

Alternately, the following PowerCLI command may be used:

```
Get-VMHost | Get-AdvancedSetting -Name Security.AccountUnlockTime
```

Remediation:

To set the account lockout to 15 minutes, perform the following:

1. From the vSphere Web Client, select the host.
2. Click "Configure" -> "Settings" -> "System" -> "Advanced System Settings".
3. Enter "Security.AccountUnlockTime" in the filter.
4. Click "Edit".
5. Set the value for this parameter to 900.

Alternately, use the following PowerCLI command:

```
Get-VMHost | Get-AdvancedSetting -Name Security.AccountUnlockTime | Set-AdvancedSetting -Value 900
```

References:

1. <https://code.vmware.com/apis/196/vsphere#https://vdc-repo.vmware.com/vmwb-repository/dcr-public/6b586ed2-655c-49d9-9029-bc416323cb22/fa0b429a-a695-4c11-b7d2-2cbc284049dc/doc/vim.option.OptionManager.html>

CIS Controls:

Version 7

16 Account Monitoring and Control

Account Monitoring and Control

5 Console

This section contains recommendations related to ESXi consoles.

5.1 (L1) Ensure the DCUI timeout is set to 600 seconds or less (Scored)

Profile Applicability:

- Level 1

Description:

The Direct Console User Interface (DCUI) is used for directly logging into an ESXi host and carrying out host management tasks. This setting terminates an idle DCUI session after the specified number of seconds has elapsed.

Rationale:

Terminating idle DCUI sessions helps avoid unauthorized usage of the DCUI originating from leftover login sessions.

Audit:

To verify the DCUI timeout setting, perform the following steps:

1. From the vSphere Web Client, select the host.
2. Click "Configure" -> "Settings" -> "System" -> "Advanced System Settings".
3. Enter "UserVars.DcuiTimeOut" in the filter.
4. Verify that the value for this parameter is 600 seconds or less.

Alternately, the following PowerCLI command may be used:

```
Get-VMHost | Get-AdvancedSetting -Name UserVars.DcuiTimeOut
```

Remediation:

To correct the DCUI timeout setting, perform the following steps:

1. From the vSphere Web Client, select the host.
2. Click "Configure" -> "Settings" -> "System" -> "Advanced System Settings".
3. Enter "UserVars.DcuiTimeOut" in the filter.
4. Click "Edit".
5. Set the value for this parameter to 600 seconds or less.

Alternately, use the following PowerCLI command:

```
Get-VMHost | Get-AdvancedSetting -Name UserVars.DcuiTimeOut | Set-AdvancedSetting -Value 600
```

References:

1. <http://pubs.vmware.com/vsphere-65/topic/com.vmware.wssdk.apiref.doc/vim.option.OptionManager.html>

CIS Controls:

Version 7

16.11 Lock Workstation Sessions After Inactivity

Automatically lock workstation sessions after a standard period of inactivity.

5.2 (L2) Ensure DCUI is disabled (Scored)

Profile Applicability:

- Level 2

Description:

The Direct Console User Interface (DCUI) allows for low-level host configuration such as configuring IP address, hostname, and root password as well as diagnostic capabilities such as enabling the ESXi shell, viewing log files, restarting agents, and resetting configurations. The DCUI can be disabled to prevent any local administration from the host. Once the DCUI is disabled, any administration of the ESXi host must be done through vCenter.

Rationale:

Actions performed from the DCUI are not tracked by vCenter Server. Even if Lockdown Mode is enabled, users who are members of the DCUI.Access list can perform administrative tasks in the DCUI, bypassing role-based access control and auditing controls provided through vCenter. Disabling DCUI prevents all local activity, and thus forces actions to be performed in vCenter Server, where they can be centrally audited and monitored.

Audit:

To verify DCUI is disabled, perform the following:

1. From the vSphere web client, select the host.
2. Select "Configure" -> "System" -> "Security Profile".
3. Scroll down to "Services".
4. Click "Edit...".
5. Select "Direct Console UI".
6. Verify the Startup Policy is set to "Start and Stop Manually".

Alternately, the following PowerCLI command may be used:

```
# List DCUI settings for all hosts
Get-VMHost | Get-VMHostService | Where { $_.key -eq "DCUI" }
```

Remediation:

To disable DCUI, perform the following:

1. From the vSphere web client, select the host.

2. Select "Configure" -> "System" -> "Security Profile".
3. Scroll down to "Services".
4. Click "Edit...".
5. Select "Direct Console UI".
6. Click "Stop".
7. Change the Startup Policy to "Start and Stop Manually".
8. Click "OK".

Alternately, use the following PowerCLI command:

```
# Set DCUI to start manually rather than automatically for all hosts
Get-VMHost | Get-VMHostService | Where { $_.key -eq "DCUI" } | Set-
VMHostService -Policy Off
```

Impact:

Disabling the DCUI can create a potential "lockout" situation, should the host become isolated from vCenter Server. Recovering from a "lockout" scenario requires reinstalling ESXi. Consider leaving DCUI enabled, and instead enable lockdown mode and limit the users allowed to access the DCUI using the DCUI.Access list.

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-6779F098-48FE-4E22-B116-A8353D19FF56.html>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

5.3 (L1) Ensure the ESXi shell is disabled (Scored)

Profile Applicability:

- Level 1

Description:

The ESXi shell is an interactive command line environment available from the Direct Console User Interface (DCUI) or remotely via SSH. The ESXi shell should only be enabled on a host when running diagnostics or troubleshooting.

Rationale:

Activities performed from the ESXi shell bypass vCenter RBAC and audit controls, so the ESXi shell should only be enabled when needed to troubleshoot/resolve problems that cannot be fixed through the vSphere web client or vCLI/PowerCLI.

Audit:

To verify the ESXi shell is disabled, perform the following:

1. From the vSphere web client, select the host.
2. Select "Configure" -> "System" -> "Security Profile".
3. Scroll down to "Services".
4. Click "Edit...".
5. Select "ESXi Shell".
6. Verify the Startup Policy is set to "Start and Stop Manually".

Alternately, the following PowerCLI command may be used:

```
# Check if the ESXi shell is running and set to start
Get-VMHost | Get-VMHostService | Where { $_.key -eq "TSM" } | Select VMHost,
Key, Label, Policy, Running, Required
```

Note: A host warning is displayed in the web client whenever the ESXi shell is enabled on a host.

Remediation:

To disable the ESXi shell, perform the following:

1. From the vSphere web client, select the host.
2. Select "Configure" -> "System" -> "Security Profile".
3. Scroll down to "Services".

4. Click "Edit..."
5. Select "ESXi Shell".
6. Click "Stop".
7. Change the Startup Policy to "Start and Stop Manually".
8. Click "OK".

Alternately, use the following PowerCLI command:

```
# Set the ESXi shell to start manually rather than automatically for all hosts
Get-VMHost | Get-VMHostService | Where { $_.key -eq "TSM" } | Set-VMHostService -Policy Off
```

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-B5144CE9-F8BB-494D-8F5D-0D5621D65DAE.html>
2. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-DFA67697-232E-4F7D-860F-96C0819570A8.html>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

5.4 (L1) Ensure SSH is disabled (Scored)

Profile Applicability:

- Level 1

Description:

The ESXi shell, when enabled, can be accessed directly from the host console through the DCUI or remotely using SSH. Disable Secure Shell (SSH) for each ESXi host to prevent remote access to the ESXi shell, and only enable SSH when needed for troubleshooting or diagnostics.

Rationale:

Remote access to the host should be limited to the vSphere Client, remote command-line tools (vCLI/PowerCLI), and through the published APIs. Under normal circumstances, remote access to the host using SSH should be disabled.

Audit:

To verify SSH is disabled, perform the following:

1. From the vSphere web client, select the host.
2. Select "Configure" -> "System" -> "Security Profile".
3. Scroll down to "Services".
4. Click "Edit...".
5. Select "SSH".
6. Verify the Startup Policy is set to "Start and Stop Manually".

Alternately, the following PowerCLI command may be used:

```
# Check if SSH is running and set to start
Get-VMHost | Get-VMHostService | Where { $_.key -eq "TSM-SSH" } | Select
VMHost, Key, Label, Policy, Running, Required
```

Note: A host warning is displayed in the web client whenever SSH is enabled on a host.

Remediation:

To disable SSH, perform the following:

1. From the vSphere web client, select the host.
2. Select "Configure" -> "System" -> "Security Profile".
3. Scroll down to "Services".

4. Click "Edit...".
5. Select "SSH".
6. Click "Stop".
7. Change the Startup Policy to "to Start and Stop Manually".
8. Click "OK".

Alternately, use the following PowerCLI command:

```
# Set SSH to start manually rather than automatically for all hosts
Get-VMHost | Get-VMHostService | Where { $_.key -eq "TSM-SSH" } | Set-
VMHostService -Policy Off
```

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-12E27BF3-3769-4665-8769-DA76C2BC9FFE.html>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

5.5 (L1) Ensure CIM access is limited (Not Scored)

Profile Applicability:

- Level 1

Description:

The Common Information Model (CIM) system provides an interface that enables hardware-level management from remote applications using a set of standard APIs. Provide only the minimum access necessary to applications. Do not provision CIM-based hardware monitoring tools and other third-party applications to run as root or as another administrator account. Instead, create a dedicated service account specific to each CIM application with the minimal access and privileges needed for that application.

Rationale:

If CIM-based hardware monitoring tools or other third-party applications are granted unneeded administrator level access, they could potentially be used to compromise the security of the host.

Audit:

To verify CIM access is limited, check for a limited-privileged service account with the following CIM roles applied:

```
Host.Config.SystemManagement Host.CIM.CIMInteraction
```

Alternately, the following PowerCLI command may be used:

```
# List all user accounts on the Host -Host Local connection required-  
Get-VMHostAccount
```

Remediation:

To limit CIM access, perform the following:

1. Create a limited-privileged service account for CIM and other third-party applications.
2. This account should access the system via vCenter.
3. Give the account the "CIM Interaction" privilege only. This will enable the account to obtain a CIM ticket, which can then be used to perform both read and write CIM operations on the target host. If an account must connect to the host directly, this account must be granted the full "Administrator" role on the host. This is not recommended unless required by the monitoring software being used.

Alternately, run the following PowerCLI command:

```
# Create a new host user account -Host Local connection required-  
New-VMHostAccount -ID ServiceUser -Password <password> -UserAccount
```

References:

1. http://pubs.vmware.com/vsphere-6-5/index.jsp?topic=%2Fcom.vmware.cimsdk.smashpg.doc%2F03_CIM_SMASH_PG_Use_Cases.5.1.html
2. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-645EBD81-CF86-44D7-BE77-224EF963D145.html>

CIS Controls:

Version 7

4.3 Ensure the Use of Dedicated Administrative Accounts

Ensure that all users with administrative account access use a dedicated or secondary account for elevated activities. This account should only be used for administrative activities and not internet browsing, email, or similar activities.

5.6 (L1) Ensure Lockdown mode is enabled (Scored)

Profile Applicability:

- Level 1

Description:

Enabling lockdown mode disables direct local access to an ESXi host, requiring the host be managed remotely from vCenter Server.

There are some operations, such as backup and troubleshooting, that require direct access to the host. In these cases, lockdown mode can be disabled on a temporary basis for specific hosts as needed, and then re-enabled when the task is completed.

Note: Lockdown mode does not apply to users who log in using authorized keys. Also, users in the DCUI.Access list for each host are allowed to override lockdown mode and log in to the DCUI. By default, the "root" user is the only user listed in the DCUI.Access list.

Rationale:

Lockdown mode limits ESXi host access to the vCenter server to ensure the roles and access controls implemented in vCenter are always enforced and users cannot bypass them by logging into a host directly. By forcing all interaction to occur through vCenter Server, the risk of someone inadvertently attaining elevated privileges or performing tasks that are not properly audited is greatly reduced.

Audit:

To verify lockdown mode is enabled, perform the following from the vSphere web client:

1. Select the host.
2. Select "Configure" -> "System" -> "Security Profile".
3. Scroll down to "Lockdown Mode".
4. Click "Edit...".
5. Ensure the "Enable Lockdown Mode" checkbox is checked.

Alternately, the following PowerCLI command may be used:

```
# To check if Lockdown mode is enabled
Get-VMHost | Select
Name,@{N="Lockdown";E={$_.Extensiondata.Config.adminDisabled}}
```

Remediation:

To enable lockdown mode, perform the following from the vSphere web client:

1. Select the host.
2. Select "Configure" -> "System" -> "Security Profile".
3. Scroll down to "Lockdown Mode".
4. Click "Edit...".
5. Select the "Enable Lockdown Mode" checkbox.
6. Click "OK".

Alternately, run the following PowerCLI command:

```
# Enable lockdown mode for each host
Get-VMHost | Foreach { $_.EnterLockdownMode() }
```

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-88B24613-E8F9-40D2-B838-225F5FF480FF.html>
2. <http://kb.vmware.com/kb/1008077>

5.7 (L2) Ensure the SSH `authorized_keys` file is empty (Scored)

Profile Applicability:

- Level 2

Description:

ESXi hosts come with Secure Shell (SSH), which can be configured to authenticate remote users using public key authentication. For day-to-day operations, the ESXi host should be in lockdown mode with the SSH service disabled. Lockdown mode does not prevent root users from logging in using keys. The presence of a remote user's public key in the `/etc/ssh/keys-root/authorized_keys` file on an ESXi host identifies the user as trusted, meaning the user is granted access to the host without providing a password.

Disabling `authorized_keys` access may limit your ability to run unattended remote scripts.

Rationale:

Keeping the `authorized_keys` file empty prevents users from circumventing the intended restrictions of lockdown mode.

Audit:

To verify the `authorized_keys` file does not contain any keys, perform the following:

1. Logon to the ESXi shell as root or another admin user.
2. Verify the `/etc/ssh/keys-root/authorized_keys` file is empty.

Remediation:

To remove all keys from the `authorized_keys` file, perform the following:

1. Logon to the ESXi shell as root or another admin user.
2. Edit the `/etc/ssh/keys-root/authorized_keys` file.
3. Remove all keys from the file and save the file.

Default Value:

The file is empty by default.

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-392ADDE9-FD3B-49A2-BF64-4ACBB60EB149.html>
2. <http://pubs.vmware.com/vsphere-60/topic/com.vmware.vsphere.security.doc/GUID-ED477079-1E7E-4EBA-AAFE-019FB335DABC.html>

5.8 (L1) Ensure idle ESXi shell and SSH sessions time out after 300 seconds or less (Scored)

Profile Applicability:

- Level 1

Description:

The `ESXiShellInteractiveTimeout` allows you to automatically terminate idle ESXi shell and SSH sessions. The permitted idle time should be 300 seconds or less.

Rationale:

If a user forgets to log out of an ESXi shell or SSH session, the idle session will exist indefinitely, increasing the potential for someone to gain unauthorized privileged access to the host, unless a timeout is set.

Audit:

To verify the timeout is set correctly, perform the following from the vSphere web client:

1. Select the host.
2. Click "Configure" -> "System" -> "Advanced System Settings".
3. Type `ESXiShellInteractiveTimeout` in the filter.
4. Verify that the attribute is set to 300 seconds or less.

Note: A value of 0 disables the `ESXiShellInteractiveTimeout`.

Alternately, the following PowerCLI command may be used:

```
# List UserVars.ESXiShellInteractiveTimeout for each host
Get-VMHost | Select Name, @{N="UserVars.ESXiShellInteractiveTimeout";E={$_. |
Get-AdvancedSetting UserVars.ESXiShellInteractiveTimeout | Select -
ExpandProperty Values}}
```

Remediation:

To set the timeout to the desired value, perform the following from the vSphere web client:

1. Select the host.
2. Click "Configure" -> "System" -> "Advanced System Settings".
3. Type `ESXiShellInteractiveTimeout` in the filter.
4. Click on the attribute to highlight it.
5. Click the pencil icon to edit.
6. Set the attribute to the desired value (300 seconds or less).

7. Click "OK".

Note: A value of 0 disables the ESXi ShellInteractiveTimeOut.

Alternately, use the following PowerCLI command:

```
# Set Remove UserVars.ESXiShellInteractiveTimeOut to 300 on all hosts
Get-VMHost | Get-AdvancedSetting -Name 'UserVars.ESXiShellInteractiveTimeOut'
| Set-AdvancedSetting -Value "300"
```

References:

1. [http://pubs.vmware.com/vsphere-6-5/index.jsp?topic=%2Fcom.vmware.powercli.cmdletref.doc%2FGet-VMHostPatch.html&resultof=%22%24ESXCLI.software.vib.list\(\)%22%20](http://pubs.vmware.com/vsphere-6-5/index.jsp?topic=%2Fcom.vmware.powercli.cmdletref.doc%2FGet-VMHostPatch.html&resultof=%22%24ESXCLI.software.vib.list()%22%20)
2. <http://kb.vmware.com/kb/2004746>
3. <https://docs.vmware.com/en/VMware-vSphere/index.html#com.vmware.vsphere.security.doc/GUID-94F0C54F-05E3-4E16-8027-0280B9ED1009.html>

CIS Controls:

Version 7

16.11 Lock Workstation Sessions After Inactivity

Automatically lock workstation sessions after a standard period of inactivity.

5.9 (L1) Ensure the shell services timeout is set to 1 hour or less (Scored)

Profile Applicability:

- Level 1

Description:

When the ESXi shell or SSH services are enabled on a host, they will run indefinitely. To avoid this, set the `ESXiShellTimeOut`, which defines a window of time after which the ESXi shell and SSH services will automatically be terminated.

It is recommended to set the `ESXiShellInteractiveTimeOut` together with `ESXiShellTimeOut`.

Rationale:

This reduces the risk of an inactive ESXi shell or SSH service being misused by an unauthorized party to compromise a host.

Audit:

To verify the timeout is set to one hour or less, perform the following from the vSphere web client:

1. Select the host and click "Configure" -> "System" -> "Advanced System Settings".
2. Type `ESXiShellTimeOut` in the filter.
3. Ensure the attribute is set to 3600 seconds (1 hour) or less.

Alternately, the following PowerCLI command may be used:

```
# List UserVars.ESXiShellTimeOut in minutes for each host
Get-VMHost | Select Name, @{N="UserVars.ESXiShellTimeOut";E={$_.Get-AdvancedSettings UserVars.ESXiShellTimeOut | Select -ExpandProperty Values}}
```

Remediation:

To set the timeout to the desired value, perform the following from the vSphere web client:

1. Select the host and click "Configure" -> "System" -> "Advanced System Settings".
2. Type `ESXiShellTimeOut` in the filter.
3. Click on the attribute to highlight it.
4. Click the pencil icon to edit.
5. Set the attribute to 3600 seconds (1 hour) or less.
6. Click "OK".

Note: A value of 0 disables the ESXiShellTimeOut.
Alternately, run the following PowerCLI command:

```
# Set UserVars.ESXiShellTimeOut to 3600 on all hosts
Get-VMHost | Get-AdvancedSetting -Name 'UserVars.ESXiShellTimeOut' | Set-AdvancedSetting -Value "3600"
```

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-6E1ECA4D-B617-4D42-B40B-71E4C83DEEFB.html>
2. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-B314F79B-2BDD-4D68-8096-F009B87ACB33.html>
3. <http://kb.vmware.com/kb/2004746>
4. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-94F0C54F-05E3-4E16-8027-0280B9ED1009.html>

CIS Controls:

Version 7

16.11 Lock Workstation Sessions After Inactivity

Automatically lock workstation sessions after a standard period of inactivity.

5.10 (L1) Ensure DCUI has a trusted users list for lockdown mode (Not Scored)

Profile Applicability:

- Level 1

Description:

Lockdown mode disables direct host access, requiring admins to manage hosts from vCenter. Set DCUI.Access to a list of highly trusted users who would be able to override lockdown mode and access the DCUI in the event an ESXi host became isolated from vCenter.

NOTE: If you disable lockdown mode using the DCUI, all users with the DCUI.Access privilege will be granted the Administrator role on the host.

Rationale:

The list prevents all admins from becoming locked out and no longer being able to manage the host.

Audit:

To verify a proper trusted users list is set for DCUI, perform the following from the vSphere web client:

1. Select the host.
2. Select "Configure" -> "System" -> "Advanced System Settings".
3. Type `DCUI.Access` in the filter.
4. Ensure the `DCUI.Access` attribute is set to a comma-separated list of the users who are allowed to override lockdown mode.

Alternately, the following PowerCLI command may be used:

```
Get-VMHost | Get-AdvancedSetting -Name DCUI.Access
```

Remediation:

To set a trusted users list for DCUI, perform the following from the vSphere web client:

1. Select the host.
2. Select "Configure" -> "System" -> "Advanced System Settings".
3. Type `DCUI.Access` in the filter.

4. Click on the attribute to highlight it.
5. Click edit.
6. Set the `DCUI.Access` attribute to a comma-separated list of the users who are allowed to override lockdown mode.
7. Click "OK".

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-6779F098-48FE-4E22-B116-A8353D19FF56.html>

CIS Controls:

Version 7

16.6 Maintain an Inventory of Accounts

Maintain an inventory of all accounts organized by authentication system.

5.11 (L2) Ensure contents of exposed configuration files have not been modified (Not Scored)

Profile Applicability:

- Level 2

Description:

Although most configurations on ESXi are controlled via an API, there are a limited set of configuration files that are used directly to govern host behavior. These files are exposed via the vSphere HTTPS-based file transfer API. These files should be monitored for modifications.

WARNING: Do not attempt to monitor files that are NOT exposed via this file transfer API, since this can result in a destabilized system.

Rationale:

Any changes to these files should be correlated with an approved administrative action, such as an authorized configuration change. Tampering with these files could enable unauthorized access to the host configuration and virtual machines.

Audit:

To verify the exposed configuration files have not been modified, perform the following:

1. Open a web browser.
2. Find the ESXi configuration files by browsing to `https://host` (not available if MOB is disabled).
3. Review the contents of those files to confirm no unauthorized modifications have been made.

NOTE: Not all the files listed are modifiable.

Alternately, the configuration files can also be retrieved using the vCLI or PowerCLI.

Remediation:

Restore all modified configuration files to a known good state by restoring backups or using other means.

To help prevent future occurrences, you can back up the host configuration data after configuring or reconfiguring an ESXi host. The `vicfg-cfgbackup` command is available only for ESXi hosts; it is not available through a vCenter Server system connection. No

equivalent ESXCLI command is supported.

To help identify future occurrences more quickly, implement a procedure to monitor the files and their contents over time to ensure they are not improperly modified. Be sure not to monitor log files and other files whose content is expected to change regularly due to system activity. Also, account for configuration file changes that are due to authorized administrative activity.

Note: Host Profiles may also be used to track configuration changes on the host; however, Host Profiles do not track all configuration changes.

References:

1. <https://pubs.vmware.com/vsphere-6-5/index.jsp>

CIS Controls:

Version 7

5.1 Establish Secure Configurations

Maintain documented, standard security configuration standards for all authorized operating systems and software.

5.5 Implement Automated Configuration Monitoring Systems

Utilize a Security Content Automation Protocol (SCAP) compliant configuration monitoring system to verify all security configuration elements, catalog approved exceptions, and alert when unauthorized changes occur.

14.9 Enforce Detail Logging for Access or Changes to Sensitive Data

Enforce detailed audit logging for access to sensitive data or changes to sensitive data (utilizing tools such as File Integrity Monitoring or Security Information and Event Monitoring).

6 Storage

This section contains recommendations related to ESXi disk and other storage-related settings.

6.1 (L1) Ensure bidirectional CHAP authentication for iSCSI traffic is enabled (Scored)

Profile Applicability:

- Level 1

Description:

vSphere allows for the use of bidirectional authentication of both the iSCSI target and host. Bidirectional Challenge-Handshake Authentication Protocol (CHAP), also known as Mutual CHAP, should be enabled to provide bidirectional authentication.

Rationale:

By not authenticating both the iSCSI target and host, there is a potential for a man-in-the-middle attack in which an attacker might impersonate either side of the connection to steal data. Bidirectional authentication can mitigate this risk.

Note: Choosing not to enforce bidirectional authentication can make sense if you create a dedicated network or VLAN to service all your iSCSI devices. If the iSCSI facility is isolated from general network traffic, it is less vulnerable to exploitation.

Audit:

To verify that bidirectional CHAP authentication is enabled for iSCSI traffic, perform the following:

1. From the vSphere Web Client, navigate to "Hosts and Clusters".
2. Click on a host.
3. Click on "Configure" -> "Storage" -> "Storage Adapters".
4. Select the iSCSI adapter.
5. Under Adapter Details, click the Properties tab.
6. Verify that the authentication method is "Use bidirectional CHAP".

Alternately, the following PowerCLI command may be used:

```
# List Iscsi Initiator and CHAP Name if defined
Get-VMHost | Get-VMHostHba | Where {$_.Type -eq "Iscsi"} | Select VMHost,
Device, ChapType, @{N="CHAPName";E={$_.AuthenticationProperties.ChapName}}
```

Remediation:

To enable bidirectional CHAP authentication for iSCSI traffic, perform the following:

1. From the vSphere Web Client, navigate to "Hosts and Clusters".
2. Click on a host.
3. Click on "Configure" -> "Storage" -> "Storage Adapters".
4. Select the iSCSI adapter to configure OR click the green plus symbol to create a new adapter.
5. Under Adapter Details, click the Properties tab and click "Edit" in the Authentication panel.
6. Specify authentication method: "Use bidirectional CHAP".
7. Specify the outgoing CHAP name.
 - Make sure that the name you specify matches the name configured on the storage side.
 - To set the CHAP name to the iSCSI adapter name, select "Use initiator name".
 - To set the CHAP name to anything other than the iSCSI initiator name, deselect "Use initiator name" and type a name in the Name text box.
8. Enter an outgoing CHAP secret to be used as part of authentication. Use the same secret as your storage side secret.
9. Specify incoming CHAP credentials. Make sure your outgoing and incoming secrets do not match.
10. Click OK.
11. Click the second to last symbol to rescan the iSCSI adapter.

Alternately, run the following PowerCLI command:

```
# Set the Chap settings for the Iscsi Adapter
Get-VMHost | Get-VMHostHba | Where {$_.Type -eq "Iscsi"} | Set-VMHostHba #
Use desired parameters here
```

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.storage.doc/GUID-AC65D747-728F-4109-96DD-49B433E2F266.html>
2. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.storage.doc/GUID-2F1E64DB-20BB-4D18-A083-8E65FE380899.html>

6.2 (L1) Ensure the uniqueness of CHAP authentication secrets for iSCSI traffic (Not Scored)

Profile Applicability:

- Level 1

Description:

Challenge-Handshake Authentication Protocol (CHAP) requires both client and host to know the secret (password) to establish a connection. Each mutual authentication secret should be unique.

Rationale:

If all mutual authentication secrets are unique, compromise of one secret does not allow an attacker to authenticate to other hosts or clients using that same secret.

Audit:

To verify the CHAP secrets are unique, run the following to list all iSCSI adapters and their corresponding CHAP configuration:

```
# List Iscsi Initiator and CHAP Name if defined
Get-VMHost | Get-VMHostHba | Where {$_.Type -eq "Iscsi"} | Select VMHost,
Device, ChapType, @{N="CHAPName";E={$_.AuthenticationProperties.ChapName}}
```

Remediation:

To change the values of CHAP secrets so they are unique, perform the following:

1. From the vSphere Web Client, navigate to "Hosts".
2. Click on a host.
3. Click on "Configure" -> "Storage" -> "Storage Adapters".
4. Select the iSCSI adapter to configure OR click the green plus symbol to create a new adapter.
5. Under Adapter Details, click the Properties tab and click "Edit" in the Authentication panel.
6. Specify the authentication method.
 - None
 - Use unidirectional CHAP if required by target
 - Use unidirectional CHAP unless prohibited by target
 - Use unidirectional CHAP
 - Use bidirectional CHAP
7. Specify the outgoing CHAP name.

- Make sure that the name you specify matches the name configured on the storage side.
 - To set the CHAP name to the iSCSI adapter name, select "Use initiator name".
 - To set the CHAP name to anything other than the iSCSI initiator name, deselect "Use initiator name" and type a name in the Name text box.
- 8. Enter an outgoing CHAP secret to be used as part of authentication. Use the same secret as your storage side secret.
- 9. If configuring with bidirectional CHAP, specify incoming CHAP credentials.
 - Make sure your outgoing and incoming secrets do not match.
- 10. Click OK.
- 11. Click the second to last symbol to rescan the iSCSI adapter.

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.storage.doc/GUID-AC65D747-728F-4109-96DD-49B433E2F266.html>
2. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.storage.doc/GUID-2F1E64DB-20BB-4D18-A083-8E65FE380899.html>

6.3 (L1) Ensure storage area network (SAN) resources are segregated properly (Not Scored)

Profile Applicability:

- Level 1

Description:

Use zoning and logical unit number (LUN) masking to segregate storage area network (SAN) activity.

Zoning provides access control in the SAN topology. Zoning defines which host bus adapters (HBAs) can connect to which targets. The devices outside a zone are not visible to the devices inside the zone when SAN zoning is configured. For example, zones defined for testing should be managed independently within the SAN so they do not interfere with activity in the production zones. Similarly, you can set up different zones for different departments. Zoning must take into account any host groups that have been set up on the SAN device.

LUN masking is a process that makes a LUN available to some hosts and unavailable to other hosts.

Rationale:

Segregating SAN activity can reduce the attack surface for the SAN, prevent non-ESXi systems from accessing SANs, and separate environments, for example, test and production environments.

Audit:

The audit procedures to verify SAN activity is properly segregated are SAN vendor or product-specific.

Remediation:

The remediation procedures to properly segregate SAN activity are SAN vendor or product-specific.

In general, with ESXi hosts, use a single-initiator zoning or a single-initiator-single-target zoning. The latter is a preferred zoning practice. Using the more restrictive zoning prevents problems and misconfigurations that can occur on the SAN.

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.storage.doc/GUID-6029358F-8EE8-4143-9BB0-16ABB3CA0FE3.html>
2. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-BFE9046A-2278-4026-809A-ED8F9D8FDACE.html>
3. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.storage.doc/GUID-39A4551F-4B03-43A6-BEDF-FAB1528C070D.html>

6.4 (L2) Ensure VMDK files are zeroed out prior to deletion (Not Scored)

Profile Applicability:

- Level 2

Description:

The CLI command 'vmkfstools --writezeroes' can be used to write zeros to the entire contents of a virtual machine disk (VMDK) file prior to its deletion.

Rationale:

Zeroing out a VMDK file before deleting the file can help prevent users from reconstructing the original contents of the file from the physical storage media.

Audit:

Not applicable

Remediation:

When deleting a VMDK file with sensitive data:

1. Shut down or stop the virtual machine.
2. Issue the CLI command 'vmkfstools --writezeroes' on that file prior to deleting it from the datastore.

Impact:

When you use this command, you lose any existing data on the virtual disk.

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.storage.doc/GUID-050C0FEE-2C75-4356-B9E0-CC802333FF41.html>

7 vNetwork

This section contains recommendations related to configuring vNetwork.

7.1 (L1) *Ensure the vSwitch Forged Transmits policy is set to reject (Scored)*

Profile Applicability:

- Level 1

Description:

Set the vSwitch Forged Transmits policy to reject for each vSwitch. Reject Forged Transmit can be set at the vSwitch and/or the Portgroup level. You can override switch-level settings at the Portgroup level.

Rationale:

If the virtual machine operating system changes the MAC address, the operating system can send frames with an impersonated source MAC address at any time. This allows an operating system to stage malicious attacks on the devices in a network by impersonating a network adaptor authorized by the receiving network. Setting forged transmissions to accept means the virtual switch does not compare the source and effective MAC addresses. To protect against MAC address impersonation, all virtual switches should have forged transmissions set to reject.

Audit:

To verify the policy is set to reject forged transmissions, perform the following:

1. In the vSphere Web Client, navigate to the host.
2. Go to "Hosts and Clusters" -> "vCenter" -> host.
3. On the Configure tab, click Networking, and select Virtual switches.
4. Select a standard switch from the list and click the pencil icon to edit settings.
5. Select Security.
6. Verify Forged transmits is set to "Reject".

Alternately, the following PowerCLI command may be used:

```
# List all vSwitches and their Security Settings
Get-VirtualSwitch -Standard | Select VMHost, Name, `
  @{N="MacChanges";E={if ($_.ExtensionData.Spec.Policy.Security.MacChanges) {
    "Accept" } Else { "Reject" } }}, `
```

```
@{N="PromiscuousMode";E={if
($_.ExtensionData.Spec.Policy.Security.PromiscuousMode) { "Accept" } Else {
"Reject"} }}, `
@{N="ForgedTransmits";E={if
($_.ExtensionData.Spec.Policy.Security.ForgedTransmits) { "Accept" } Else {
"Reject"} }}
```

Remediation:

To set the policy to reject forged transmissions, perform the following:

1. In the vSphere Web Client, navigate to the host.
2. Go to "Hosts and Clusters" -> "vCenter" -> host.
3. On the Configure tab, click Networking, and select Virtual switches.
4. Select a standard switch from the list and click the pencil icon to edit settings.
5. Select Security.
6. Set Forged transmits to "Reject".
7. Click "OK".

Alternately, the following ESXi shell command may be used:

```
# esxcli network vswitch standard policy security set -v vSwitch2 -f false
```

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.networking.doc/GUID-891147DD-3E2E-45A1-9B50-7717C3443DD7.html>

CIS Controls:

Version 7

12.4 Deny Communication over Unauthorized Ports

Deny communication over unauthorized TCP or UDP ports or application traffic to ensure that only authorized protocols are allowed to cross the network boundary in or out of the network at each of the organization's network boundaries.

7.2 (L1) Ensure the vSwitch MAC Address Change policy is set to reject (Scored)

Profile Applicability:

- Level 1

Description:

Ensure the MAC Address Change policy within the vSwitch is set to reject. Reject MAC Changes can be set at the vSwitch and/or the Portgroup level. You can override switch-level settings at the Portgroup level.

Rationale:

If the virtual machine operating system changes the MAC address, it can send frames with an impersonated source MAC address at any time. This allows it to stage malicious attacks on the devices in a network by impersonating a network adaptor authorized by the receiving network.

Audit:

To verify the policy is set to reject, perform the following:

1. In the vSphere Web Client, navigate to the host.
2. Go to "Hosts and Clusters" -> "vCenter" -> host.
3. On the Configure tab, click Networking, and select Virtual switches.
4. Select a standard switch from the list and click the pencil icon to edit settings.
5. Select Security.
6. Verify MAC Address Changes is set to "Reject".
7. Click "OK".

Alternately, the following PowerCLI command may be used:

```
# List all vSwitches and their Security Settings
Get-VirtualSwitch -Standard | Select VMHost, Name, `
  @{N="MacChanges";E={if ($_.ExtensionData.Spec.Policy.Security.MacChanges) {
    "Accept" } Else { "Reject" } }}, `
  @{N="PromiscuousMode";E={if
($_.ExtensionData.Spec.Policy.Security.PromiscuousMode) { "Accept" } Else {
"Reject" } }}, `
  @{N="ForgedTransmits";E={if
($_.ExtensionData.Spec.Policy.Security.ForgedTransmits) { "Accept" } Else {
"Reject" } }}
```

Remediation:

To set the policy to reject, perform the following:

1. In the vSphere Web Client, navigate to the host.
2. Go to "Hosts and Clusters" -> "vCenter" -> host.
3. On the Configure tab, click Networking, and select Virtual switches.
4. Select a standard switch from the list and click the pencil icon to edit settings.
5. Select Security.
6. Set MAC Address Changes to "Reject".
7. Click "OK".

Alternately, perform the following using the ESXi shell:

```
# esxcli network vswitch standard policy security set -v vSwitch2 -m false
```

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.networking.doc/GUID-891147DD-3E2E-45A1-9B50-7717C3443DD7.html>

CIS Controls:

Version 7

12.4 Deny Communication over Unauthorized Ports

Deny communication over unauthorized TCP or UDP ports or application traffic to ensure that only authorized protocols are allowed to cross the network boundary in or out of the network at each of the organization's network boundaries.

7.3 (L1) Ensure the vSwitch Promiscuous Mode policy is set to reject (Scored)

Profile Applicability:

- Level 1

Description:

Ensure the Promiscuous Mode Policy within the vSwitch is set to reject. Promiscuous mode can be set at the vSwitch and/or the Portgroup level. You can override switch-level settings at the Portgroup level.

Rationale:

When promiscuous mode is enabled for a virtual switch, all virtual machines connected to the dvPortgroup have the potential of reading all packets crossing that network. This could enable unauthorized access to the contents of those packets.

Audit:

To verify the policy is set to reject, perform the following:

1. In the vSphere Web Client, navigate to the host.
2. Go to "Hosts and Clusters" -> "vCenter" -> host.
3. On the Configure tab, click Networking, and select Virtual switches.
4. Select a standard switch from the list and click the pencil icon to edit settings.
5. Select Security.
6. Verify Promiscuous Mode is set to "Reject".
7. Click "OK".

Alternately, the following PowerCLI command may be used:

```
# List all vSwitches and their Security Settings
Get-VirtualSwitch -Standard | Select VMHost, Name, `
  @{N="MacChanges";E={if ($_.ExtensionData.Spec.Policy.Security.MacChanges) {
"Accept" } Else { "Reject" } }}, `
  @{N="PromiscuousMode";E={if
($_.ExtensionData.Spec.Policy.Security.PromiscuousMode) { "Accept" } Else {
"Reject" } }}, `
  @{N="ForgedTransmits";E={if
($_.ExtensionData.Spec.Policy.Security.ForgedTransmits) { "Accept" } Else {
"Reject" } }}
```

Remediation:

To set the policy to reject, perform the following:

1. In the vSphere Web Client, navigate to the host.
2. Go to "Hosts and Clusters" -> "vCenter" -> host.
3. On the Configure tab, click Networking, and select Virtual switches.
4. Select a standard switch from the list and click the pencil icon to edit settings.
5. Select Security.
6. Set Promiscuous Mode to "Reject".
7. Click "OK".

Alternately, perform the following via the ESXi shell:

```
# esxcli network vswitch standard policy security set -v vSwitch2 -p false
```

Default Value:

reject

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.networking.doc/GUID-891147DD-3E2E-45A1-9B50-7717C3443DD7.html>

CIS Controls:

Version 7

12.4 Deny Communication over Unauthorized Ports

Deny communication over unauthorized TCP or UDP ports or application traffic to ensure that only authorized protocols are allowed to cross the network boundary in or out of the network at each of the organization's network boundaries.

7.4 (L1) Ensure port groups are not configured to the value of the native VLAN (Scored)

Profile Applicability:

- Level 1

Description:

ESXi does not use the concept of native VLAN, so do not configure port groups to use the native VLAN ID. If the default value of 1 for the native VLAN is being used, the ESXi Server virtual switch port groups should be configured with any value between 2 and 4094. Otherwise, ensure that the port group is not configured to use whatever value is set for the native VLAN.

Rationale:

Frames with VLAN specified in the port group will have a tag, but frames without a VLAN specified in the port group are not tagged and therefore will end up as belonging to the native VLAN of the physical switch. For example, frames on VLAN 1 from a Cisco physical switch will be untagged, because this is considered as the native VLAN. However, frames from ESXi specified as VLAN 1 will be tagged with a "1"; therefore, traffic from ESXi that is destined for the native VLAN will not be correctly routed (because it is tagged with a "1" instead of being untagged), and traffic from the physical switch coming from the native VLAN will not be visible (because it is not tagged). If the ESXi virtual switch port group uses the native VLAN ID, traffic from those VMs will not be visible to the native VLAN on the switch, because the switch is expecting untagged traffic.

Audit:

To verify the native VLAN ID is not being used for port groups, perform the following:

1. From the vSphere web client, select the host.
2. On the Configure tab, click Networking, and select Virtual switches.
3. Select a standard switch from the list.
4. View the topology diagram of the switch, which shows the various port groups associated with that switch.
5. For each port group on the vSwitch, verify and record the VLAN IDs used.

Alternately, the following PowerCLI command may be used:

```
# List all vSwitches, their Portgroups and VLAN IDs
Get-VirtualPortGroup -Standard | Select virtualSwitch, Name, VlanID
```

Remediation:

To stop using the native VLAN ID for port groups, perform the following:

1. From the vSphere web client, select the host.
2. On the Configure tab, click Networking, and select Virtual switches.
3. Select a standard switch from the list.
4. View the topology diagram of the switch, which shows the various port groups associated with that switch.
5. For each port group on the vSwitch, verify and record the VLAN IDs used.
6. If a VLAN ID change is needed, click the name of the port group in the topology diagram of the virtual switch.
7. Click the "Edit settings" pencil icon under the topology diagram title.
8. In the Properties section, name the port group in the Network Label text field.
9. Choose an existing VLAN ID drop-down menu or type in a new one.

References:

1. http://pubs.vmware.com/vsphere-6-5/index.jsp?topic=%2Fcom.vmware.vcli.migration.doc%2Fcos_upgrade_technote.1.9.html
2. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.networking.doc/GUID-3A9D9911-3632-4B81-9D2E-A2F9F2D01180.html>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

7.5 (L1) Ensure port groups are not configured to VLAN values reserved by upstream physical switches (Not Scored)

Profile Applicability:

- Level 1

Description:

Ensure that port groups are not configured to VLAN values reserved by upstream physical switches. Certain physical switches reserve certain VLAN IDs for internal purposes and often disallow traffic configured to these values. For example, Cisco Catalyst switches typically reserve VLANs 1001 through 1024 and 4094, while Nexus switches typically reserve 3968 through 4047 and 4094. Check the documentation for your specific switch.

Rationale:

Using a reserved VLAN might result in a denial of service on the network.

Audit:

To verify port groups are not using reserved VLAN values, perform the following:

1. From the vSphere web client, select the host.
2. On the Configure tab, click Networking, and select Virtual switches.
3. Select a standard switch from the list.
4. View the topology diagram of the switch, which shows the various port groups associated with that switch.
5. For each port group on the vSwitch, verify and record the VLAN IDs used.

Alternately, the following PowerCLI command may be used:

```
# List all vSwitches, their Portgroups and VLAN IDs  
Get-VirtualPortGroup -Standard | Select virtualSwitch, Name, VlanID
```

Remediation:

To change the VLAN values for port groups to non-reserved values, perform the following:

1. From the vSphere web client, select the host.
2. On the Configure tab, click Networking, and select Virtual switches.
3. Select a standard switch from the list.
4. View the topology diagram of the switch, which shows the various port groups associated with that switch.
5. For each port group on the vSwitch, verify and record the VLAN IDs used.

6. If a VLAN ID change is needed, click the name of the port group in the topology diagram of the virtual switch.
7. Click the "Edit settings" pencil icon under the topology diagram title.
8. In the Properties section, name the port group in the Network Label text field.
9. Choose an existing VLAN ID drop-down menu or type in a new one.

References:

1. <http://www.cisco.com/c/en/us/td/docs/switches/lan/catalyst4500/12-2/20ew/configuration/guide/config/vlans.html#wp1038758>
2. http://www.cisco.com/c/en/us/td/docs/switches/datacenter/nexus5500/sw/layer2/7x/b_5500_Layer2_Config_7x/b_5500_Layer2_Config_7x_chapter_010.html#con_1143823

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

7.6 (L1) Ensure port groups are not configured to VLAN 4095 except for Virtual Guest Tagging (VGT) (Scored)

Profile Applicability:

- Level 1

Description:

Port groups should not be configured to VLAN 4095 except for Virtual Guest Tagging (VGT). When a port group is set to VLAN 4095, this activates VGT mode. In this mode, the vSwitch passes all network frames to the guest virtual machine without modifying the VLAN tags, leaving it up to the guest to deal with them. VLAN 4095 should be used only if the guest has been specifically configured to manage VLAN tags itself.

Rationale:

If VGT is enabled inappropriately, it might cause a denial of service or allow a guest virtual machine to interact with traffic on an unauthorized VLAN.

Audit:

To verify port groups are not set to 4095 unless VGT is required, perform the following:

1. From the vSphere web client, select the host.
2. On the Configure tab, click Networking, and select Virtual switches.
3. Select a standard switch from the list.
4. View the topology diagram of the switch, which shows the various port groups associated with that switch.
5. For each port group on the vSwitch, verify and record the VLAN IDs used.

Additionally, the following PowerCLI command may be used:

```
# List all vSwitches, their Portgroups and VLAN IDs
Get-VirtualPortGroup -Standard | Select virtualSwitch, Name, VlanID
```

Remediation:

To set port groups to values other than 4095 unless VGT is required, perform the following:

1. From the vSphere web client, select the host.
2. On the Configure tab, click Networking, and select Virtual switches.
3. Select a standard switch from the list.

4. View the topology diagram of the switch, which shows the various port groups associated with that switch.
5. For each port group on the vSwitch, verify and record the VLAN IDs used.
6. If a VLAN ID change is needed, click the name of the port group in the topology diagram of the virtual switch.
7. Click the "Edit settings" pencil icon under the topology diagram title.
8. In the Properties section, name the port group in the Network Label text field.
9. Choose an existing VLAN ID drop-down menu or type in a new one.

References:

1. <http://www.cisco.com/c/en/us/td/docs/switches/lan/catalyst4500/12-2/20ew/configuration/guide/config/vlans.html#wp1038758>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

8 Virtual Machines

This section contains recommendations for settings related to guest virtual machines.

8.1 Communication

8.1.1 (L1) Ensure informational messages from the VM to the VMX file are limited (Scored)

Profile Applicability:

- Level 1

Description:

Limit informational messages from the virtual machine (VM) to the virtual machine extensions (VMX) file to avoid filling the datastore. The configuration file containing these name-value pairs is limited to a size of 1 MB by default. This should be sufficient for most cases, but you can change this value if necessary, such as if large amounts of custom information are being stored in the configuration file.

Rationale:

Filling the datastore with informational messages from the VM to the VMX file could cause a denial of service.

Audit:

To verify informational messages are limited to 1 MB, view the virtual machine configuration file and verify that `tools.setInfo.sizeLimit` is set to `1048576`.

Additionally, the following PowerCLI command may be used:

```
# List the VMs and their current settings
Get-VM | Get-AdvancedSetting -Name "tools.setInfo.sizeLimit" | Select Entity,
Name, Value
```

Remediation:

To limit informational messages to 1 MB, run the following PowerCLI command:

```
# Add the setting to all VMs
Get-VM | New-AdvancedSetting -Name "tools.setInfo.sizeLimit" -value 1048576
```

Default Value:

1048576

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-91BF834E-CB92-4014-8CF7-29CE40F3E8A3.html>

8.1.2 (L2) Ensure only one remote console connection is permitted to a VM at any time (Scored)

Profile Applicability:

- Level 2

Description:

By default, remote console sessions can be connected to by more than one user at a time. Permit only one remote console connection to a VM at a time. Other attempts will be rejected until the first connection disconnects.

Rationale:

When multiple sessions are activated, each terminal window gets a notification about the new session. If an administrator in the VM logs in using a VMware remote console during their session, a non-administrator in the VM can connect to the console and observe the administrator's actions. Also, this could result in an administrator losing console access to a VM. For example, if a jump box is being used for an open console session, and the admin loses a connection to that box, the console session remains open. Allowing two console sessions permits debugging via a shared session. For highest security, only one remote console session at a time should be allowed.

Audit:

To verify that only one remote console session is permitted at a time, view the virtual machine configuration file and confirm that `RemoteDisplay.maxConnections` is set to 1. Alternately, the following PowerCLI command may be used:

```
# List the VMs and their current settings
Get-VM | Get-AdvancedSetting -Name "RemoteDisplay.maxConnections" | Select
Entity, Name, Value
```

Remediation:

To permit only one remote console session at a time, run the following PowerCLI command for VMs that do not specify the setting:

```
# Add the setting to all VMs
Get-VM | New-AdvancedSetting -Name "RemoteDisplay.maxConnections" -value 1
```

Run the following PowerCLI command for VMs that specify the setting but have the wrong value for it:

```
# Add the setting to all VMs
Get-VM | New-AdvancedSetting -Name "RemoteDisplay.maxConnections" -value 1 -
Force
```

References:

1. <https://pubs.vmware.com/vsphere-6-5/index.jsp?topic=%2Fcom.vmware.vcli.examples.doc%2FGUID-0885D02A-872B-4D98-A20E-7B55373C529C.html>
2. <http://www.ibenit.com/post/85227299008/security-benchmark-hardening-guide-policies-and-profile>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

8.2 Devices

8.2.1 (L1) Ensure unnecessary floppy devices are disconnected (Scored)

Profile Applicability:

- Level 1

Description:

Ensure that no floppy device is connected to a virtual machine unless required. For a floppy device to be disconnected, the floppyX.present parameter should either not be present or have a value of FALSE.

Rationale:

Removing unnecessary hardware devices can reduce the number of potential attack channels and help prevent attacks.

Audit:

To verify floppy drives are not connected, confirm that the following parameter is either NOT present or is set to FALSE: floppyX.present
Alternately, the following PowerCLI command may be used:

```
# Check for Floppy Devices attached to VMs
Get-VM | Get-FloppyDrive | Select Parent, Name, ConnectionState
```

Remediation:

To disconnect all floppy drives from VMs, run the following PowerCLI command:

```
# Remove all Floppy drives attached to VMs
Get-VM | Get-FloppyDrive | Remove-FloppyDrive
```

The VM will need to be powered off for this change to take effect.

References:

1. <https://pubs.vmware.com/vsphere-6-5/index.jsp?topic=%2Fcom.vmware.vcli.examples.doc%2FGUID-F9B3FBA2-CC36-4E21-8029-89C68DD3A50C.html>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

8.2.2 (L2) Ensure unnecessary CD/DVD devices are disconnected (Scored)

Profile Applicability:

- Level 2

Description:

Ensure that no CD/DVD device is connected to a virtual machine unless required. For a CD/DVD device to be disconnected, the ideX:Y.present parameter should either not be present or have a value of FALSE.

Rationale:

Removing unnecessary hardware devices can reduce the number of potential attack channels and help prevent attacks.

Audit:

To verify CD/DVD drives are not connected, confirm that the following parameter is either NOT present or is set to FALSE: ideX:Y.present

Alternately, the following PowerCLI command may be used:

```
# Check for CD/DVD Drives attached to VMs
Get-VM | Get-CDDrive
```

Remediation:

To disconnect all CD/DVD drives from VMs, run the following PowerCLI command:

```
# Remove all CD/DVD Drives attached to VMs
Get-VM | Get-CDDrive | Remove-CDDrive
```

The VM will need to be powered off for this change to take effect.

References:

1. <https://pubs.vmware.com/vsphere-6-5/index.jsp?topic=%2Fcom.vmware.vcli.examples.doc%2FGUID-F9B3FBA2-CC36-4E21-8029-89C68DD3A50C.html>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

8.2.3 (L1) Ensure unnecessary parallel ports are disconnected (Scored)

Profile Applicability:

- Level 1

Description:

Ensure that no parallel port is connected to a virtual machine unless required. For a parallel port to be disconnected, the parallelX.present parameter should either not be present or have a value of FALSE.

Rationale:

Removing unnecessary hardware devices can reduce the number of potential attack channels and help prevent attacks.

Audit:

To verify parallel ports are not connected, confirm that the following parameter is either NOT present or is set to FALSE: parallelX.present

Alternately, the following PowerCLI command may be used:

```
# In this Example you will need to add the functions from this post:
http://blogs.vmware.com/vipowershell/2012/05/working-with-vm-devices-in-
powercli.html
# Check for Parallel ports attached to VMs
Get-VM | Get-ParallelPort
```

Remediation:

To disconnect all parallel ports from VMs, run the following PowerCLI command:

```
# In this Example you will need to add the functions from this post:
http://blogs.vmware.com/vipowershell/2012/05/working-with-vm-devices-in-
powercli.html
# Remove all Parallel Ports attached to VMs
Get-VM | Get-ParallelPort | Remove-ParallelPort
```

The VM will need to be powered off for this change to take effect.

References:

1. <https://blogs.vmware.com/PowerCLI/2012/05/working-with-vm-devices-in-powercli.html>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

8.2.4 (L1) Ensure unnecessary serial ports are disconnected (Scored)

Profile Applicability:

- Level 1

Description:

Ensure that no serial port is connected to a virtual machine unless required. For a serial port to be disconnected, the serialX.present parameter should either not be present or have a value of FALSE.

Rationale:

Removing unnecessary hardware devices can reduce the number of potential attack channels and help prevent attacks.

Audit:

To verify serial ports are not connected, confirm that the following parameter is either NOT present or is set to FALSE: serialX.present

Alternately, the following PowerCLI command may be used:

```
# In this Example you will need to add the functions from this post:
http://blogs.vmware.com/vipowershell/2012/05/working-with-vm-devices-in-
powercli.html
# Check for Serial ports attached to VMs
Get-VM | Get-SerialPort
```

Remediation:

To disconnect all serial ports from VMs, run the following PowerCLI command:

```
# In this Example you will need to add the functions from this post:
http://blogs.vmware.com/vipowershell/2012/05/working-with-vm-devices-in-
powercli.html
# Remove all Serial Ports attached to VMs
Get-VM | Get-SerialPort | Remove-SerialPort
```

The VM will need to be powered off for this change to take effect.

References:

1. <https://blogs.vmware.com/PowerCLI/2012/05/working-with-vm-devices-in-powercli.html>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

8.2.5 (L1) Ensure unnecessary USB devices are disconnected (Scored)

Profile Applicability:

- Level 1

Description:

Ensure that no USB device is connected to a virtual machine unless required. For a USB device to be disconnected, the usb.present parameter should either not be present or have a value of FALSE.

Rationale:

Removing unnecessary hardware devices can reduce the number of potential attack channels and help prevent attacks.

Audit:

To verify USB devices are not connected, confirm that the following parameter is either NOT present or is set to FALSE: usb.present

Alternately, the following PowerCLI command may be used:

```
# Check for USB Devices attached to VMs
Get-VM | Get-USBDevice
```

Remediation:

To disconnect all USB devices from VMs, run the following PowerCLI command:

```
# Remove all USB Devices attached to VMs
Get-VM | Get-USBDevice | Remove-USBDevice
```

The VM will need to be powered off for this change to take effect.

References:

1. <https://pubs.vmware.com/vsphere-6-5/index.jsp?topic=%2Fcom.vmware.powercli.cmdletref.doc%2FUsbDevice.html&resultof=%22%67%65%74%2d%75%73%62%64%65%76%69%63%65%22%20>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

8.2.6 (L1) Ensure unauthorized modification and disconnection of devices is disabled (Scored)

Profile Applicability:

- Level 1

Description:

In a virtual machine, users and processes without root or administrator privileges can disconnect devices, such as network adapters and CD-ROM drives, and modify device settings within the guest operating system. These actions should be prevented.

Rationale:

Disabling unauthorized modification and disconnection of devices helps prevent unauthorized changes within the guest operating system, which could be used to gain unauthorized access, cause denial of service conditions, and otherwise negatively affect the security of the guest operating system.

Audit:

To verify unauthorized device modifications and disconnections are prevented, access the virtual machine configuration file and verify that `isolation.device.edit.disable` is set to `TRUE`.

Alternately, the following PowerCLI command may be used:

```
# List the VMs and their current settings
Get-VM | Get-AdvancedSetting -Name "isolation.device.edit.disable" | Select
Entity, Name, Value
```

Remediation:

To prevent unauthorized device modifications and disconnections, run the following PowerCLI command:

```
# Add the setting to all VMs
Get-VM | New-AdvancedSetting -Name "isolation.device.edit.disable" -value
$true
```

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-F88A5FED-552B-44F9-A168-C62D9306DBD6.html>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

8.2.7 (L1) Ensure unauthorized connection of devices is disabled (Scored)

Profile Applicability:

- Level 1

Description:

In a virtual machine, users and processes without root or administrator privileges can connect devices, such as network adapters and CD-ROM drives. This should be prevented.

Rationale:

Disabling unauthorized connection of devices helps prevent unauthorized changes within the guest operating system, which could be used to gain unauthorized access, cause denial of service conditions, and otherwise negatively affect the security of the guest operating system.

Audit:

To verify unauthorized device connections are prevented, access the virtual machine configuration file and verify that `isolation.device.connectable.disable` is set to `TRUE`. Alternately, the following PowerCLI command may be used:

```
# List the VMs and their current settings
Get-VM | Get-AdvancedSetting -Name "isolation.device.connectable.disable" |
Select Entity, Name, Value
```

Remediation:

To prevent unauthorized device connections, run the following PowerCLI command:

```
# Add the setting to all VMs
Get-VM | New-AdvancedSetting -Name "isolation.device.connectable.disable" -
value $true
```

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-F88A5FED-552B-44F9-A168-C62D9306DBD6.html>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

8.3 Guest

8.3.1 (L1) Ensure unnecessary or superfluous functions inside VMs are disabled (Not Scored)

Profile Applicability:

- Level 1

Description:

Disable all system components that are not needed to support the application or service running on the VM. VMs often don't require as many functions as ordinary physical servers, so when virtualizing, you should evaluate whether a particular function is truly needed.

Rationale:

By disabling unnecessary system components, you reduce the number of potential attack vectors, which reduces the likelihood of compromise.

Audit:

To verify unneeded functions are disabled, check that the following are disabled:

1. Unused services in the operating system. For example, if the system runs a file server, Web services should not be running.
2. Unused physical devices, such as CD/DVD drives, floppy drives, and USB adaptors.
3. Screen savers.
4. X Windows if using a Linux, BSD, or Solaris guest operating system.

Remediation:

To disable unneeded functions, perform whichever of the following steps are applicable:

1. Disable unused services in the operating system.
2. Disconnect unused physical devices, such as CD/DVD drives, floppy drives, and USB adaptors.
3. Turn off any screen savers.
4. If using a Linux, BSD, or Solaris guest operating system, do not run the X Windows system unless it is necessary.

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-6BFA8CA7-610F-4E6B-9FC6-D656917B7E7A.html>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

8.3.2 (L1) Ensure use of the VM console is limited (Not Scored)

Profile Applicability:

- Level 1

Description:

The VM console enables you to connect to the console of a VM, in effect seeing what a monitor on a physical server would show. The VM console also provides power management and removable device connectivity controls. Instead of the VM console, use native remote management services, such as terminal services and ssh, to interact with VMs. Grant access to the VM console only when needed, and use custom roles to provide fine-grained permissions for those people who do need access. By default, the vCenter roles "Virtual Machine Power User" and "Virtual Machine Administrator" have the "Virtual Machine.Interaction.Console Interaction" privilege.

Rationale:

The VM console could be misused to eavesdrop on VM activity, cause VM outages, and negatively affect the performance of the console, especially if many VM console sessions are open simultaneously.

Audit:

To verify use of the VM console is properly limited, perform the following steps:

1. From the vSphere Client, select an object in the inventory.
2. Click the Permissions tab to view the user and role pair assignments for that object.
3. Next, navigate to vCenter --> Administration --> Roles.
4. Select the role in question and choose Edit to see which effective privileges are enabled.
5. Verify that only authorized users have a role which allows them a privilege under the Virtual Machine section of the role editor.

Remediation:

To properly limit use of the VM console, perform the following steps:

1. From the vSphere Client, navigate to vCenter --> Administration --> Roles.
2. Create a custom role and choose Edit to enable only the minimum needed effective privileges.
3. Next, select an object in the inventory.
4. Click the Permissions tab to view the user and role pair assignments for that object.

5. Remove any default "Admin" or "Power User" roles, and assign the new custom role as needed.

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-41E5E52E-A95B-4E81-9724-6AD6800BEF78.html>
2. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-3D47149A-947D-4608-88B3-E5811129EFA8.html>

CIS Controls:

Version 7

16.1 Maintain an Inventory of Authentication Systems

Maintain an inventory of each of the organization's authentication systems, including those located onsite or at a remote service provider.

8.3.3 (L1) Ensure secure protocols are used for virtual serial port access (Not Scored)

Profile Applicability:

- Level 1

Description:

Serial ports are interfaces for connecting peripherals to the VM. They are often used on physical systems to provide a direct, low-level connection to the console of a server. Virtual serial ports allow VMs to communicate with serial ports over networks. If virtual serial ports are needed, they should be configured to use secure protocols.

Rationale:

If virtual serial ports do not use secure protocols, the communications with those ports could be eavesdropped on, manipulated, or otherwise compromised, giving attackers sensitive information or control to unauthorized parties.

Audit:

To verify that all virtual serial ports use secure protocols, check that all configured protocols are from this list:

- ssl - the equivalent of TCP+SSL
- tcp+ssl - SSL over TCP over IPv4 or IPv6
- tcp4+ssl - SSL over TCP over IPv4
- tcp6+ssl - SSL over TCP over IPv6
- telnets - telnet over SSL over TCP

Remediation:

To configure all virtual serial ports to use secure protocols, change any protocols that are not secure to one of the following:

- ssl - the equivalent of TCP+SSL
- tcp+ssl - SSL over TCP over IPv4 or IPv6
- tcp4+ssl - SSL over TCP over IPv4
- tcp6+ssl - SSL over TCP over IPv6
- telnets - telnet over SSL over TCP

References:

1. <https://code.vmware.com/apis/196/vsphere#/doc/vim.vm.device.VirtualSerialPort.URIBackingInfo.html>
2. https://pubs.vmware.com/vsphere-6-5/index.jsp?topic=%2Fcom.vmware.wssdk.vsp.doc%2Fvirtual_serial_port_using_proxy_Chapter1.3.2.html
3. https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.vm_admin.doc/GUID-462B8B04-29DF-406B-9585-12D2588A6A48.html

CIS Controls:

Version 7

12.4 Deny Communication over Unauthorized Ports

Deny communication over unauthorized TCP or UDP ports or application traffic to ensure that only authorized protocols are allowed to cross the network boundary in or out of the network at each of the organization's network boundaries.

8.3.4 (L1) Ensure templates are used whenever possible to deploy VMs (Not Scored)

Profile Applicability:

- Level 1

Description:

Use a hardened base operating system template image to create application-specific templates, and use the application-specific templates to deploy virtual machines.

Rationale:

By capturing a hardened base operating system image (with no applications installed) in a template, you can ensure that all your virtual machines are created with a known baseline level of security. Manual installation of the OS and applications into a VM introduces the risk of misconfiguration due to human or process error.

Audit:

To verify that templates are used whenever possible to deploy VMs, confirm that such templates exist, the templates are properly configured, and standard procedures and processes use the templates when appropriate.

Remediation:

To change current practices so templates are used whenever possible to deploy VMs, perform whichever of the following steps is appropriate:

- Create templates and configure them properly
- Alter standard procedures and processes to use the templates

Also, ensure that the applications do not depend on information specific to the VM to be deployed.

References:

1. https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.vm_admin.doc/GUID-8254CD05-CC06-491D-BA56-A773A32A8130.html
2. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-3399BC47-45E8-494B-9B57-E498DD294A47.html>

CIS Controls:

Version 7

5.1 Establish Secure Configurations

Maintain documented, standard security configuration standards for all authorized operating systems and software.

5.2 Maintain Secure Images

Maintain secure images or templates for all systems in the enterprise based on the organization's approved configuration standards. Any new system deployment or existing system that becomes compromised should be imaged using one of those images or templates.

8.4 Monitor

8.4.1 (L1) Ensure access to VMs through the dvfilter network APIs is configured correctly (Not Scored)

Profile Applicability:

- Level 1

Description:

A VM must be configured explicitly to accept access by the dvfilter network API. Only VMs that need to be accessed by that API should be configured to accept such access.

Rationale:

An attacker might compromise a VM by making use of the dvfilter API.

Audit:

To verify the configuration, perform the following if dvfilter access should be permitted:

1. Verify that the following is in the VMX file: `ethernet0.filter1.name = dv-filter1` where `ethernet0` is the network adapter interface of the virtual machine that is to be protected, `filter1` is the number of the filter that is being used, and `dv-filter1` is the name of the particular data path kernel module that is protecting the VM.
2. Ensure that the name of the data path kernel is set correctly.

Perform the following to verify the configuration if dvfilter access should not be permitted:

1. Verify that the following is not in the VMX file: `ethernet0.filter1.name = dv-filter1`.

Remediation:

To configure a VM to allow dvfilter access, perform the following steps:

1. Configure the following in the VMX file: `ethernet0.filter1.name = dv-filter1` where `ethernet0` is the network adapter interface of the virtual machine that is to be protected, `filter1` is the number of the filter that is being used, and `dv-filter1` is the name of the particular data path kernel module that is protecting the VM.
2. Set the name of the data path kernel correctly.

To configure a VM to not allow dvfilter access, perform the following steps:

1. Remove the following from its VMX file: `ethernet0.filter1.name = dv-filter1`.

References:

1. <http://kb.vmware.com/kb/1714>
2. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-CD0783C9-1734-4B9A-B821-ED17A77B0206.html>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

12.4 Deny Communication over Unauthorized Ports

Deny communication over unauthorized TCP or UDP ports or application traffic to ensure that only authorized protocols are allowed to cross the network boundary in or out of the network at each of the organization's network boundaries.

8.4.2 (L1) Ensure VMsafe Agent Address is configured correctly (Not Scored)

Profile Applicability:

- Level 1

Description:

The VMsafe CPU/memory API allows a security virtual machine to inspect and modify the contents of the memory and CPU registers on other VMs, for the purpose of detecting and preventing malware attacks. A VM must be configured explicitly to accept access by the VMsafe CPU/memory API. This involves three parameters to perform the following:

1. Enable the API.
2. Set the IP address used by the security virtual appliance on the introspection vSwitch.
3. Set the port number for that IP address.

The second parameter must be set correctly in the `vmsafe.agentAddress` option in the virtual machine configuration file for any VMs that should be protected by the API.

Rationale:

An attacker might compromise the VMs by making unauthorized use of the introspection channel provided by the API.

Audit:

To verify the VMsafe Agent Address is configured correctly, perform the following steps:

1. If the VM is not being protected by a VMsafe CPU/memory product, verify that `vmsafe.agentAddress` is not present in the virtual machine configuration file.
2. If the VM is being protected by a VMsafe CPU/Memory product, make sure that `vmsafe.agentAddress` in the virtual machine configuration file is set to the correct value.

Alternately, the following PowerCLI command may be used:

```
# List the VMs and their current settings
Get-VM | Get-AdvancedSetting -Name "vmsafe.agentAddress" | Select Entity,
Name, Value
```

Remediation:

To configure the VMsafe Agent Address correctly, perform the following steps:

1. If the VM is not being protected by a VMsafe CPU/memory product, remove `vm-safe.agentAddress` from the virtual machine configuration file.
2. If the VM is being protected by a VMsafe CPU/Memory product, set `vm-safe.agentAddress` to the correct value.

References:

1. <http://kb.vmware.com/kb/1714>
2. <https://www.vmware.com/security/hardening-guides.html>

CIS Controls:

Version 7

8.3 Enable Operating System Anti-Exploitation Features/ Deploy Anti-Exploit Technologies

Enable anti-exploitation features such as Data Execution Prevention (DEP) or Address Space Layout Randomization (ASLR) that are available in an operating system or deploy appropriate toolkits that can be configured to apply protection to a broader set of applications and executables.

8.4.3 (L1) Ensure VMsafe Agent Port is configured correctly (Not Scored)

Profile Applicability:

- Level 1

Description:

The VMsafe CPU/memory API allows a security virtual machine to inspect and modify the contents of the memory and CPU registers on other VMs, for the purpose of detecting and preventing malware attacks. A VM must be configured explicitly to accept access by the VMsafe CPU/memory API. This involves three parameters to perform the following:

1. Enable the API.
2. Set the IP address used by the security virtual appliance on the introspection vSwitch.
3. Set the port number for that IP address.

The third parameter must be set correctly in the `vmsafe.agentPort` option in the virtual machine configuration file for any VMs that should be protected by the API.

Rationale:

An attacker might compromise the VMs by making unauthorized use of the introspection channel provided by the API.

Audit:

To verify the VMsafe Agent Port is configured correctly, perform the following steps:

1. If the VM is not being protected by a VMsafe CPU/memory product, verify that `vmsafe.agentPort` is not present in the virtual machine configuration file.
2. If the VM is being protected by a VMsafe CPU/Memory product, make sure that `vmsafe.agentPort` in the virtual machine configuration file is set to the correct value.

Alternately, the following PowerCLI command may be used:

```
# List the VMs and their current settings
Get-VM | Get-AdvancedSetting -Name "vmsafe.agentPort" | Select Entity, Name, Value
```

Remediation:

To configure the VMsafe Agent Port correctly, perform the following steps:

1. If the VM is not being protected by a VMsafe CPU/memory product, remove `vmSafe.agentPort` from the virtual machine configuration file.
2. If the VM is being protected by a VMsafe CPU/Memory product, set `vmSafe.agentPort` to the correct value.

References:

1. <http://kb.vmware.com/kb/1714>
2. <https://www.vmware.com/security/hardening-guides.html>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

8.4.4 (L1) Ensure VMsafe Agent is configured correctly (Not Scored)

Profile Applicability:

- Level 1

Description:

The VMsafe CPU/memory API allows a security virtual machine to inspect and modify the contents of the memory and CPU registers on other VMs, for the purpose of detecting and preventing malware attacks. A VM must be configured explicitly to accept access by the VMsafe CPU/memory API. This involves three parameters to perform the following:

1. Enable the API.
2. Set the IP address used by the security virtual appliance on the introspection vSwitch.
3. Set the port number for that IP address.

The first parameter must be set correctly in the `vmSAFE.enable` option in the virtual machine configuration file for any VMs that should be protected by the API. For any VMs that should not be protected by the API, this option should not exist in the configuration file.

Rationale:

An attacker might compromise the VMs by making unauthorized use of the introspection channel provided by the API.

Audit:

To verify the VMsafe Agent is configured correctly, perform the following steps:

1. If the VM is not being protected by a VMsafe CPU/memory product, verify that `vmSAFE.enable` is not present in the virtual machine configuration file or is set to `FALSE`.
2. If the VM is being protected by a VMsafe CPU/Memory product, make sure that `vmSAFE.enable` in the virtual machine configuration file is set to the correct value.

Alternately, the following PowerCLI command may be used:

```
# List the VMs and their current settings
Get-VM | Get-AdvancedSetting -Name "vmSAFE.enable" | Select Entity, Name, Value
```

Remediation:

To configure the VMsafe Agent correctly, perform the following steps:

1. If the VM is not being protected by a VMsafe CPU/memory product, remove `vmSAFE.enable` from the virtual machine configuration file or set it to a value of `FALSE`.
2. If the VM is being protected by a VMsafe CPU/Memory product, set `vmSAFE.enable` to the correct value.

Default Value:

The prescribed state is the default state.

References:

1. <http://kb.vmware.com/kb/1714>
2. <https://www.vmware.com/security/hardening-guides.html>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

8.4.5 (L2) Ensure Autologon is disabled (Scored)

Profile Applicability:

- Level 2

Description:

Autologon should be disabled if it is not needed.

Rationale:

Some VMX parameters don't apply on vSphere because VMware virtual machines work on vSphere and hosted virtualization platforms such as Workstation and Fusion. The code paths for these features are not implemented in ESXi. Explicitly disabling these features, such as autologon, reduces the potential for vulnerabilities because it reduces the number of ways in which a guest can affect the host. Note that these are referenced for organizations that insist any documented setting, regardless of whether it is implemented in code or not, must have a value.

Audit:

To verify that autologon is disabled if not needed, check the virtual machine configuration file and verify that `isolation.tools.ghi.autologon.disable` is set to `TRUE`.

Alternately, the following PowerCLI command may be used:

```
# List the VMs and their current settings
Get-VM | Get-AdvancedSetting -Name "isolation.tools.ghi.autologon.disable" |
Select Entity, Name, Value
```

Remediation:

To disable autologon, run the following PowerCLI command:

```
# Add the setting to all VMs
Get-VM | New-AdvancedSetting -Name "isolation.tools.ghi.autologon.disable" -
value $true
```

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-60E83710-8295-41A2-9C9D-83DEBB6872C2.html>

8.4.6 (L2) Ensure BIOS BBS is disabled (Scored)

Profile Applicability:

- Level 2

Description:

BIOS BBS should be disabled if it is not needed.

Rationale:

Some VMX parameters don't apply on vSphere because VMware virtual machines work on vSphere and hosted virtualization platforms such as Workstation and Fusion. The code paths for these features are not implemented in ESXi. Explicitly disabling these features, such as BIOS BBS, reduces the potential for vulnerabilities because it reduces the number of ways in which a guest can affect the host. Note that these are referenced for organizations that insist any documented setting, regardless of whether it is implemented in code or not, must have a value.

Audit:

To verify that BIOS BBS is disabled if not needed, check the virtual machine configuration file and verify that `isolation.bios.bbs.disable` is set to `TRUE`.

Alternately, the following PowerCLI command may be used:

```
# List the VMs and their current settings
Get-VM | Get-AdvancedSetting -Name "isolation.bios.bbs.disable" | Select
Entity, Name, Value
```

Remediation:

To disable BIOS BBS, run the following PowerCLI command:

```
# Add the setting to all VMs
Get-VM | New-AdvancedSetting -Name "isolation.bios.bbs.disable" -value $true
```

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-60E83710-8295-41A2-9C9D-83DEBB6872C2.html>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

8.4.7 (L2) Ensure Guest Host Interaction Protocol Handler is set to disabled (Scored)

Profile Applicability:

- Level 2

Description:

Guest Host Interaction Protocol Handle should be disabled if it is not needed.

Rationale:

Some VMX parameters don't apply on vSphere because VMware virtual machines work on vSphere and hosted virtualization platforms such as Workstation and Fusion. The code paths for these features are not implemented in ESXi. Explicitly disabling these features, such as Guest Host Interaction Protocol Handle, reduces the potential for vulnerabilities because it reduces the number of ways in which a guest can affect the host. Note that these are referenced for organizations that insist any documented setting, regardless of whether it is implemented in code or not, must have a value.

Audit:

To verify that Guest Host Interaction Protocol Handle is disabled if not needed, check the virtual machine configuration file and verify that

`isolation.tools.ghi.protocolhandler.info.disable` is set to `TRUE`.

Alternately, the following PowerCLI command may be used:

```
# List the VMs and their current settings
Get-VM | Get-AdvancedSetting -Name
"isolation.tools.ghi.protocolhandler.info.disable" | Select Entity, Name,
Value
```

Remediation:

To disable Guest Host Interaction Protocol Handle, run the following PowerCLI command:

```
# Add the setting to all VMs
Get-VM | New-AdvancedSetting -Name
"isolation.tools.ghi.protocolhandler.info.disable" -value $true
```

Impact:

Some automated tools and processes may cease to function.

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-60E83710-8295-41A2-9C9D-83DEBB6872C2.html>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

8.4.8 (L2) Ensure Unity Taskbar is disabled (Scored)

Profile Applicability:

- Level 2

Description:

The Unity Taskbar feature should be disabled if it is not needed.

Rationale:

Some VMX parameters don't apply on vSphere because VMware virtual machines work on vSphere and hosted virtualization platforms such as Workstation and Fusion. The code paths for these features are not implemented in ESXi. Explicitly disabling these features, such as the Unity Taskbar feature, reduces the potential for vulnerabilities because it reduces the number of ways in which a guest can affect the host. Note that these are referenced for organizations that insist any documented setting, regardless of whether it is implemented in code or not, must have a value.

Audit:

To verify that the Unity Taskbar feature is disabled if not needed, check the virtual machine configuration file and verify that `isolation.tools.unity.taskbar.disable` is set to `TRUE`. Alternately, the following PowerCLI command may be used:

```
# List the VMs and their current settings
Get-VM | Get-AdvancedSetting -Name "isolation.tools.unity.taskbar.disable" |
Select Entity, Name, Value
```

Remediation:

To disable the Unity Taskbar feature, run the following PowerCLI command:

```
# Add the setting to all VMs
Get-VM | New-AdvancedSetting -Name "isolation.tools.unity.taskbar.disable" -
value $true
```

Impact:

Some automated tools and processes may cease to function.

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-60E83710-8295-41A2-9C9D-83DEBB6872C2.html>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

8.4.9 (L2) Ensure Unity Active is disabled (Scored)

Profile Applicability:

- Level 2

Description:

The Unity Active feature should be disabled if it is not needed.

Rationale:

Some VMX parameters don't apply on vSphere because VMware virtual machines work on vSphere and hosted virtualization platforms such as Workstation and Fusion. The code paths for these features are not implemented in ESXi. Explicitly disabling these features, such as the Unity Active feature, reduces the potential for vulnerabilities because it reduces the number of ways in which a guest can affect the host. Note that these are referenced for organizations that insist any documented setting, regardless of whether it is implemented in code or not, must have a value.

Audit:

To verify that the Unity Active feature is disabled if not needed, check the virtual machine configuration file and verify that `isolation.tools.unityActive.disable` is set to `TRUE`. Alternately, the following PowerCLI command may be used:

```
# List the VMs and their current settings
Get-VM | Get-AdvancedSetting -Name "isolation.tools.unityActive.disable" |
Select Entity, Name, Value
```

Remediation:

To disable the Unity Active feature, run the following PowerCLI command:

```
# Add the setting to all VMs
Get-VM | New-AdvancedSetting -Name "isolation.tools.unityActive.disable" -
value $True
```

Impact:

Some automated tools and processes may cease to function.

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-412EF981-D4F1-430B->

9D09-

[A4679C2D04E7.html?hWord=N4IghgNiBcIMIHsB2AzAlgcwK4Cc1IwAIA1AWQHcw
cBTQgFQQQgGcQBfIA](https://docs.vmware.com/en/VMware-Tools/10.3.0/com.vmware.vsphere.vmwaretools.doc/GUID-685722FA-9009-439C-9142-18A9E7C592EA.html?hWord=N4IghgNiBcIMoFMDGBXATgSwC4E8AEAwgPYB2AzhgCYJphYall4BmRahpzGA5uhidzwA1ALIB3MGgR4AKkSIQyIAL5A)

2. <https://docs.vmware.com/en/VMware-Tools/10.3.0/com.vmware.vsphere.vmwaretools.doc/GUID-685722FA-9009-439C-9142-18A9E7C592EA.html?hWord=N4IghgNiBcIMoFMDGBXATgSwC4E8AEAwgPYB2AzhgCYJphYall4BmRahpzGA5uhidzwA1ALIB3MGgR4AKkSIQyIAL5A>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

8.4.10 (L2) Ensure Unity Window Contents is disabled (Scored)

Profile Applicability:

- Level 2

Description:

The Unity Window Contents feature should be disabled if it is not needed.

Rationale:

Some VMX parameters don't apply on vSphere because VMware virtual machines work on vSphere and hosted virtualization platforms such as Workstation and Fusion. The code paths for these features are not implemented in ESXi. Explicitly disabling these features, such as the Unity Window Contents feature, reduces the potential for vulnerabilities because it reduces the number of ways in which a guest can affect the host. Note that these are referenced for organizations that insist any documented setting, regardless of whether it is implemented in code or not, must have a value.

Audit:

To verify that the Unity Window Contents feature is disabled if not needed, check the virtual machine configuration file and verify that

`isolation.tools.unity.windowContents.disable` is set to `TRUE`.

Alternately, the following PowerCLI command may be used:

```
# List the VMs and their current settings
Get-VM | Get-AdvancedSetting -Name
"isolation.tools.unity.windowContents.disable" | Select Entity, Name, Value
```

Remediation:

To disable the Unity Window Contents feature, run the following PowerCLI command:

```
# Add the setting to all VMs
Get-VM | New-AdvancedSetting -Name
"isolation.tools.unity.windowContents.disable" -value $True
```

Impact:

Some automated tools and processes may cease to function.

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-60E83710-8295-41A2-9C9D-83DEBB6872C2.html>
2. <https://docs.vmware.com/en/VMware-Tools/10.3.0/com.vmware.vsphere.vmwaretools.doc/GUID-685722FA-9009-439C-9142-18A9E7C592EA.html?hWord=N4IghgNiBcIMoFMDGBXATgSwC4E8AEAwgPYB2AzhgCYJphYall4BmRahpzGA5uhidzwA1ALIB3MGgR4AKkSIQyIAL5A>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

8.4.11 (L2) Ensure Unity Push Update is disabled (Scored)

Profile Applicability:

- Level 2

Description:

The Unity Push Update feature should be disabled if it is not needed.

Rationale:

Some VMX parameters don't apply on vSphere because VMware virtual machines work on vSphere and hosted virtualization platforms such as Workstation and Fusion. The code paths for these features are not implemented in ESXi. Explicitly disabling these features, such as the Unity Push Update feature, reduces the potential for vulnerabilities because it reduces the number of ways in which a guest can affect the host. Note that these are referenced for organizations that insist any documented setting, regardless of whether it is implemented in code or not, must have a value.

Audit:

To verify that the Unity Push Update feature is disabled if not needed, check virtual machine configuration file and verify that `isolation.tools.unity.push.update.disable` is set to `TRUE`.

Alternately, the following PowerCLI command may be used:

```
# List the VMs and their current settings
Get-VM | Get-AdvancedSetting -Name
"isolation.tools.unity.push.update.disable" | Select Entity, Name, Value
```

Remediation:

To disable the Unity Push Update feature, run the following PowerCLI command:

```
# Add the setting to all VMs
Get-VM | New-AdvancedSetting -Name
"isolation.tools.unity.push.update.disable" -value $true
```

Impact:

Some automated tools and processes may cease to function.

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-60E83710-8295-41A2-9C9D-83DEBB6872C2.html>
2. <https://docs.vmware.com/en/VMware-Tools/10.3.0/com.vmware.vsphere.vmwaretools.doc/GUID-685722FA-9009-439C-9142-18A9E7C592EA.html?hWord=N4IghgNiBcIMoFMDGBXATgSwC4E8AEAwgPYB2AzhgCYJphYall4BmRahpzGA5uhidzwA1ALIB3MGgR4AKkSIQyIAL5A>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

8.4.12 (L2) Ensure Drag and Drop Version Get is disabled (Scored)

Profile Applicability:

- Level 2

Description:

The Drag and Drop Version Get feature should be disabled if it is not needed.

Rationale:

Some VMX parameters don't apply on vSphere because VMware virtual machines work on vSphere and hosted virtualization platforms such as Workstation and Fusion. The code paths for these features are not implemented in ESXi. Explicitly disabling these features, such as the Drag and Drop Version Get feature, reduces the potential for vulnerabilities because it reduces the number of ways in which a guest can affect the host. Note that these are referenced for organizations that insist any documented setting, regardless of whether it is implemented in code or not, must have a value.

Audit:

To verify that the Drag and Drop Version Get feature is disabled if not needed, check the virtual machine configuration file and verify that

`isolation.tools.vmxDnDVersionGet.disable` is set to `TRUE`.

Alternately, the following PowerCLI command may be used:

```
# List the VMs and their current settings
Get-VM | Get-AdvancedSetting -Name
"isolation.tools.vmxDnDVersionGet.disable" | Select Entity, Name, Value
```

Remediation:

To disable the Drag and Drop Version Get feature, run the following PowerCLI command:

```
# Add the setting to all VMs
Get-VM | New-AdvancedSetting -Name "isolation.tools.vmxDnDVersionGet.disable"
-value $true
```

Impact:

Some automated tools and processes may cease to function.

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-52188148-C579-4F6A-8335-CFBCE0DD2167.html>
2. <https://docs.vmware.com/en/VMware-Tools/10.3.0/com.vmware.vsphere.vmwaretools.doc/GUID-685722FA-9009-439C-9142-18A9E7C592EA.html?hWord=N4IghgNiBcIMoFMDGBXATgSwC4E8AEAwgPYB2AzhgCYJphYall4BmRahpzGA5uhidzwA1ALIB3MGgR4AKkSIQyIAL5A>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

8.4.13 (L2) Ensure Drag and Drop Version Set is disabled (Scored)

Profile Applicability:

- Level 2

Description:

The Drag and Drop Version Set feature should be disabled if it is not needed.

Rationale:

Some VMX parameters don't apply on vSphere because VMware virtual machines work on vSphere and hosted virtualization platforms such as Workstation and Fusion. The code paths for these features are not implemented in ESXi. Explicitly disabling these features, such as the Drag and Drop Version Set feature, reduces the potential for vulnerabilities because it reduces the number of ways in which a guest can affect the host. Note that these are referenced for organizations that insist any documented setting, regardless of whether it is implemented in code or not, must have a value.

Audit:

To verify that the Drag and Drop Version Set feature is disabled if not needed, check the virtual machine configuration file and verify that

`isolation.tools.guestDnDVersionSet.disable` is set to `TRUE`.

Alternately, the following PowerCLI command may be used:

```
# List the VMs and their current settings
Get-VM | Get-AdvancedSetting -Name
"isolation.tools.guestDnDVersionSet.disable" | Select Entity, Name, Value
```

Remediation:

To disable the Drag and Drop Version Set feature, run the following PowerCLI command:

```
# Add the setting to all VMs
Get-VM | New-AdvancedSetting -Name
"isolation.tools.guestDnDVersionSet.disable" -value $true
```

Impact:

Some automated tools and processes may cease to function.

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-52188148-C579-4F6A-8335-CFBCE0DD2167.html>
2. <https://docs.vmware.com/en/VMware-Tools/10.3.0/com.vmware.vsphere.vmwaretools.doc/GUID-685722FA-9009-439C-9142-18A9E7C592EA.html?hWord=N4IghgNiBcIMoFMDGBXATgSwC4E8AEAwgPYB2AzhgCYJphYall4BmRahpzGA5uhidzwA1ALIB3MGgR4AKkSIQyIAL5A>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

8.4.14 (L2) Ensure Shell Action is disabled (Scored)

Profile Applicability:

- Level 2

Description:

The Shell Action feature should be disabled if it is not needed.

Rationale:

Some VMX parameters don't apply on vSphere because VMware virtual machines work on vSphere and hosted virtualization platforms such as Workstation and Fusion. The code paths for these features are not implemented in ESXi. Explicitly disabling these features, such as the Shell Action feature, reduces the potential for vulnerabilities because it reduces the number of ways in which a guest can affect the host. Note that these are referenced for organizations that insist any documented setting, regardless of whether it is implemented in code or not, must have a value.

Audit:

To verify that the Shell Action feature is disabled if not needed, check the virtual machine configuration file and verify that `isolation.guest.shellAction.disable` is set to `TRUE`. Alternately, the following PowerCLI command may be used:

```
# List the VMs and their current settings
Get-VM | Get-AdvancedSetting -Name "isolation.guest.shellAction.disable" |
Select Entity, Name, Value
```

Remediation:

To disable the Shell Action feature, run the following PowerCLI command:

```
# Add the setting to all VMs
Get-VM | New-AdvancedSetting -Name "isolation.guest.shellAction.disable" -
value $true
```

Impact:

Some automated tools and processes may cease to function.

References:

1. <https://docs.vmware.com/en/VMware-Tools/10.3.0/com.vmware.vsphere.vmwaretools.doc/GUID-685722FA-9009-439C->

- 9142-18A9E7C592EA.html?hWord=N4IghgNiBcIMoFMDGBXATgSwC4E8AEAwgPYB2AzhgCYJphYall4BmRahpzGA5uhidzwA1ALIB3MGgR4AKkSIQyIAL5A
2. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-60E83710-8295-41A2-9C9D-83DEBB6872C2.html>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

8.4.15 (L2) Ensure Request Disk Topology is disabled (Scored)

Profile Applicability:

- Level 2

Description:

The Request Disk Topology feature should be disabled if it is not needed.

Rationale:

Some VMX parameters don't apply on vSphere because VMware virtual machines work on vSphere and hosted virtualization platforms such as Workstation and Fusion. The code paths for these features are not implemented in ESXi. Explicitly disabling these features, such as the Request Disk Topology feature, reduces the potential for vulnerabilities because it reduces the number of ways in which a guest can affect the host. Note that these are referenced for organizations that insist any documented setting, regardless of whether it is implemented in code or not, must have a value.

Audit:

To verify that the Request Disk Topology feature is disabled if not needed, check the virtual machine configuration file and verify that `isolation.tools.dispTopoRequest.disable` is set to `TRUE`.

Alternately, the following PowerCLI command may be used:

```
# List the VMs and their current settings
Get-VM | Get-AdvancedSetting -Name "isolation.tools.dispTopoRequest.disable" |
Select Entity, Name, Value
```

Remediation:

To disable the Request Disk Topology feature, run the following PowerCLI command:

```
# Add the setting to all VMs
Get-VM | New-AdvancedSetting -Name "isolation.tools.dispTopoRequest.disable"
-value $true
```

Impact:

Some automated tools and processes may cease to function.

References:

1. <https://docs.vmware.com/en/VMware-Tools/10.3.0/com.vmware.vsphere.vmwaretools.doc/GUID-685722FA-9009-439C-9142-18A9E7C592EA.html?hWord=N4IghgNiBcIMoFMDGBXATgSwC4E8AEAwgPYB2AzhgCYJphYall4BmRahpzGA5uhidzwA1ALIB3MGgR4AKkSIQyIAL5A>
2. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-60E83710-8295-41A2-9C9D-83DEBB6872C2.html>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

8.4.16 (L2) Ensure Trash Folder State is disabled (Scored)

Profile Applicability:

- Level 2

Description:

The Trash Folder State feature should be disabled if it is not needed.

Rationale:

Some VMX parameters don't apply on vSphere because VMware virtual machines work on vSphere and hosted virtualization platforms such as Workstation and Fusion. The code paths for these features are not implemented in ESXi. Explicitly disabling these features, such as the Trash Folder State feature, reduces the potential for vulnerabilities because it reduces the number of ways in which a guest can affect the host. Note that these are referenced for organizations that insist any documented setting, regardless of whether it is implemented in code or not, must have a value.

Audit:

To verify that the Trash Folder State feature is disabled if not needed, check the virtual machine configuration file and verify that `isolation.tools.trashFolderState.disable` is set to `TRUE`.

Alternately, the following PowerCLI command may be used:

```
# List the VMs and their current settings
Get-VM | Get-AdvancedSetting -Name
"isolation.tools.trashFolderState.disable"| Select Entity, Name, Value
```

Remediation:

To disable the Trash Folder State feature, run the following PowerCLI command:

```
# Add the setting to all VMs
Get-VM | New-AdvancedSetting -Name "isolation.tools.trashFolderState.disable"
-value $true
```

Impact:

Some automated tools and processes may cease to function.

References:

1. <https://docs.vmware.com/en/VMware-Tools/10.3.0/com.vmware.vsphere.vmwaretools.doc/GUID-685722FA-9009-439C-9142-18A9E7C592EA.html?hWord=N4IghgNiBcIMoFMDGBXATgSwC4E8AEAwgPYB2AzhgCYJphYall4BmRahpzGA5uhidzwA1ALIB3MGgR4AKkSIQyIAL5A>
2. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-60E83710-8295-41A2-9C9D-83DEBB6872C2.html>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

8.4.17 (L2) Ensure Guest Host Interaction Tray Icon is disabled (Scored)

Profile Applicability:

- Level 2

Description:

The Guest Host Interaction Tray Icon feature should be disabled if it is not needed.

Rationale:

Some VMX parameters don't apply on vSphere because VMware virtual machines work on vSphere and hosted virtualization platforms such as Workstation and Fusion. The code paths for these features are not implemented in ESXi. Explicitly disabling these features, such as the Guest Host Interaction Tray Icon feature, reduces the potential for vulnerabilities because it reduces the number of ways in which a guest can affect the host. Note that these are referenced for organizations that insist any documented setting, regardless of whether it is implemented in code or not, must have a value.

Audit:

To verify that the Guest Host Interaction Tray Icon feature is disabled if not needed, check the virtual machine configuration file and verify that

`isolation.tools.ghi.trayicon.disable` is set to `TRUE`.

Alternately, the following PowerCLI command may be used:

```
# List the VMs and their current settings
Get-VM | Get-AdvancedSetting -Name "isolation.tools.ghi.trayicon.disable" |
Select Entity, Name, Value
```

Remediation:

To disable the Guest Host Interaction Tray Icon feature, run the following PowerCLI command:

```
# Add the setting to all VMs
Get-VM | New-AdvancedSetting -Name "isolation.tools.ghi.trayicon.disable" -
value $true
```

Impact:

Some automated tools and processes may cease to function.

References:

1. <https://docs.vmware.com/en/VMware-Tools/10.3.0/com.vmware.vsphere.vmwaretools.doc/GUID-685722FA-9009-439C-9142-18A9E7C592EA.html?hWord=N4IghgNiBcIMoFMDGBXATgSwC4E8AEAwgPYB2AzhgCYJphYall4BmRahpzGA5uhidzwA1ALIB3MGgR4AKkSIQyIAL5A>
2. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-60E83710-8295-41A2-9C9D-83DEBB6872C2.html>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

8.4.18 (L2) Ensure Unity is disabled (Scored)

Profile Applicability:

- Level 2

Description:

The Unity feature should be disabled if it is not needed.

Rationale:

Some VMX parameters don't apply on vSphere because VMware virtual machines work on vSphere and hosted virtualization platforms such as Workstation and Fusion. The code paths for these features are not implemented in ESXi. Explicitly disabling these features, such as the Unity feature, reduces the potential for vulnerabilities because it reduces the number of ways in which a guest can affect the host. Note that these are referenced for organizations that insist any documented setting, regardless of whether it is implemented in code or not, must have a value.

Audit:

To verify that the Unity feature is disabled if not needed, check the virtual machine configuration file and verify that `isolation.tools.unity.disable` is set to `TRUE`. Alternately, the following PowerCLI command may be used:

```
# List the VMs and their current settings
Get-VM | Get-AdvancedSetting -Name "isolation.tools.unity.disable" | Select
Entity, Name, Value
```

Remediation:

To disable the Unity feature, run the following PowerCLI command:

```
# Add the setting to all VMs
Get-VM | New-AdvancedSetting -Name "isolation.tools.unity.disable" -value
$true
```

Impact:

Some automated tools and processes may cease to function.

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-60E83710-8295-41A2-9C9D-83DEBB6872C2.html>
2. <https://docs.vmware.com/en/VMware-Tools/10.3.0/com.vmware.vsphere.vmwaretools.doc/GUID-685722FA-9009-439C-9142-18A9E7C592EA.html?hWord=N4IghgNiBcIMoFMDGBXATgSwC4E8AEAwgPYB2AzhgCYJphYall4BmRahpzGA5uhidzwA1ALIB3MGgR4AKkSIQyIAL5A>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

8.4.19 (L2) Ensure Unity Interlock is disabled (Scored)

Profile Applicability:

- Level 2

Description:

The Unity Interlock feature should be disabled if it is not needed.

Rationale:

Some VMX parameters don't apply on vSphere because VMware virtual machines work on vSphere and hosted virtualization platforms such as Workstation and Fusion. The code paths for these features are not implemented in ESXi. Explicitly disabling these features, such as the Unity Interlock feature, reduces the potential for vulnerabilities because it reduces the number of ways in which a guest can affect the host. Note that these are referenced for organizations that insist any documented setting, regardless of whether it is implemented in code or not, must have a value.

Audit:

To verify that the Unity Interlock feature is disabled if not needed, check the virtual machine configuration file and verify that

`isolation.tools.unityInterlockOperation.disable` is set to `TRUE`.

Alternately, the following PowerCLI command may be used:

```
# List the VMs and their current settings
Get-VM | Get-AdvancedSetting -Name
"isolation.tools.unityInterlockOperation.disable"| Select Entity, Name, Value
```

Remediation:

To disable the Unity Interlock feature, run the following PowerCLI command:

```
# Add the setting to all VMs
Get-VM | New-AdvancedSetting -Name
"isolation.tools.unityInterlockOperation.disable" -value $true
```

Impact:

Some automated tools and processes may cease to function.

References:

1. <https://docs.vmware.com/en/VMware-Tools/10.3.0/com.vmware.vsphere.vmwaretools.doc/GUID-685722FA-9009-439C-9142-18A9E7C592EA.html?hWord=N4IghgNiBcIMoFMDGBXATgSwC4E8AEAwgPYB2AzhgCYJphYall4BmRahpzGA5uhidzwA1ALIB3MGgR4AKkSIQyIAL5A>
2. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-60E83710-8295-41A2-9C9D-83DEBB6872C2.html>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

8.4.20 (L2) Ensure GetCreds is disabled (Scored)

Profile Applicability:

- Level 2

Description:

The GetCreds feature should be disabled if it is not needed.

Rationale:

Some VMX parameters don't apply on vSphere because VMware virtual machines work on vSphere and hosted virtualization platforms such as Workstation and Fusion. The code paths for these features are not implemented in ESXi. Explicitly disabling these features, such as the GetCreds feature, reduces the potential for vulnerabilities because it reduces the number of ways in which a guest can affect the host. Note that these are referenced for organizations that insist any documented setting, regardless of whether it is implemented in code or not, must have a value.

Audit:

To verify that the GetCreds feature is disabled if not needed, check the virtual machine configuration file and verify that `isolation.tools.getCreds.disable` is set to `TRUE`. Alternately, the following PowerCLI command may be used:

```
# List the VMs and their current settings
Get-VM | Get-AdvancedSetting -Name "isolation.tools.getCreds.disable" | Select
Entity, Name, Value
```

Remediation:

To disable the GetCreds feature, run the following PowerCLI command:

```
# Add the setting to all VMs
Get-VM | New-AdvancedSetting -Name "isolation.tools.getCreds.disable" -value
$true
```

Impact:

Some automated tools and processes may cease to function.

References:

1. <https://docs.vmware.com/en/VMware-Tools/10.3.0/com.vmware.vsphere.vmwaretools.doc/GUID-685722FA-9009-439C->

- 9142-18A9E7C592EA.html?hWord=N4IghgNiBcIMoFMDGBXATgSwC4E8AEAwgPYB2AzhgCYJphYall4BmRahpzGA5uhidzwA1ALIB3MGgR4AKkSIQyIAL5A
2. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-60E83710-8295-41A2-9C9D-83DEBB6872C2.html>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

8.4.21 (L2) Ensure Host Guest File System Server is disabled (Scored)

Profile Applicability:

- Level 2

Description:

The Host Guest File System Server should be disabled if it is not needed.

Rationale:

Certain automated operations such as automated tool upgrades use a component in the hypervisor called Host Guest File System (HGFS), and an attacker could potentially use this to transfer files inside the guest OS. These VMX parameters don't apply on vSphere because VMware virtual machines work on vSphere and hosted virtualization platforms such as Workstation and Fusion. The code paths for these features, such as the Host Guest File System Server, are not implemented in ESXi. Explicitly disabling these features reduces the potential for vulnerabilities because it reduces the number of ways in which a guest can affect the host. Note that these are referenced for organizations that insist any documented setting, regardless of whether it is implemented in code or not, must have a value.

Audit:

To verify that the Host Guest File System Server is disabled if not needed, check the virtual machine configuration file and verify that `isolation.tools.hgfsServerSet.disable` is set to `TRUE`.

Alternately, the following PowerCLI command may be used:

```
# List the VMs and their current settings
Get-VM | Get-AdvancedSetting -Name "isolation.tools.hgfsServerSet.disable" |
Select Entity, Name, Value
```

Remediation:

To disable the Host Guest File System Server, run the following PowerCLI command:

```
# Add the setting to all VMs
Get-VM | New-AdvancedSetting -Name "isolation.tools.hgfsServerSet.disable" -
value $true
```

Impact:

This will cause the VMX process to not respond to commands from the tools process. Setting `isolation.tools.hgfsServerSet.disable` to `TRUE` disables the registration of the guest's

HGFS server with the host. APIs that use HGFS to transfer files to and from the guest operating system, such as some VIX commands or the VMware Tools auto-upgrade utility, will not function.

References:

1. <https://docs.vmware.com/en/VMware-Tools/10.3.0/com.vmware.vsphere.vmwaretools.doc/GUID-685722FA-9009-439C-9142-18A9E7C592EA.html?hWord=N4IghgNiBcIMoFMDGBXATgSwC4E8AEAwgPYB2AzhgCYJphYall4BmRahpzGA5uhidzwA1ALIB3MGgR4AKkSIQyIAL5A>
2. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-52188148-C579-4F6A-8335-CFBCE0DD2167.html>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

8.4.22 (L2) Ensure Guest Host Interaction Launch Menu is disabled (Scored)

Profile Applicability:

- Level 2

Description:

The Guest Host Interaction Launch Menu feature should be disabled if it is not needed.

Rationale:

Some VMX parameters don't apply on vSphere because VMware virtual machines work on vSphere and hosted virtualization platforms such as Workstation and Fusion. The code paths for these features are not implemented in ESXi. Explicitly disabling these features, such as the Guest Host Interaction Launch Menu feature, reduces the potential for vulnerabilities because it reduces the number of ways in which a guest can affect the host. Note that these are referenced for organizations that insist any documented setting, regardless of whether it is implemented in code or not, must have a value.

Audit:

To verify that the Guest Host Interaction Launch Menu feature is disabled if not needed, check the virtual machine configuration file and verify that

`isolation.tools.ghi.launchmenu.change` is set to `TRUE`.

Alternately, the following PowerCLI command may be used:

```
# List the VMs and their current settings
Get-VM | Get-AdvancedSetting -Name "isolation.tools.ghi.launchmenu.change" |
Select Entity, Name, Value
```

Remediation:

To disable the Guest Host Interaction Launch Menu feature, run the following PowerCLI command:

```
# Add the setting to all VMs
Get-VM | New-AdvancedSetting -Name "isolation.tools.ghi.launchmenu.change" -
value $true
```

Impact:

Some automated tools and processes may cease to function.

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-60E83710-8295-41A2-9C9D-83DEBB6872C2.html>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

8.4.23 (L2) Ensure memSchedFakeSampleStats is disabled (Scored)

Profile Applicability:

- Level 2

Description:

The memSchedFakeSampleStats feature should be disabled if it is not needed.

Rationale:

Some VMX parameters don't apply on vSphere because VMware virtual machines work on vSphere and hosted virtualization platforms such as Workstation and Fusion. The code paths for these features are not implemented in ESXi. Explicitly disabling these features, such as the memSchedFakeSampleStats feature, reduces the potential for vulnerabilities because it reduces the number of ways in which a guest can affect the host. Note that these are referenced for organizations that insist any documented setting, regardless of whether it is implemented in code or not, must have a value.

Audit:

To verify that the memSchedFakeSampleStats feature is disabled if not needed, check the virtual machine configuration file and verify that

`isolation.tools.memSchedFakeSampleStats.disable` is set to `TRUE`.

Alternately, the following PowerCLI command may be used:

```
# List the VMs and their current settings
Get-VM | Get-AdvancedSetting -Name
"isolation.tools.memSchedFakeSampleStats.disable" | Select Entity, Name,
Value
```

Remediation:

To disable the memSchedFakeSampleStats feature, run the following PowerCLI command:

```
# Add the setting to all VMs
Get-VM | New-AdvancedSetting -Name
"isolation.tools.memSchedFakeSampleStats.disable" -value $true
```

Impact:

Some automated tools and processes may cease to function.

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-60E83710-8295-41A2-9C9D-83DEBB6872C2.html>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

8.4.24 (L1) Ensure VM Console Copy operations are disabled (Scored)

Profile Applicability:

- Level 1

Description:

VM console copy operations should be disabled.

Rationale:

VM console copy operations are disabled by default (not explicitly specified); however, explicitly disabling this feature enables audit controls to check that this setting is correct.

Audit:

To verify that VM console copy operations are disabled, verify that the

`isolation.tools.copy.disable` option is missing or set to `TRUE`.

Alternately, the following PowerCLI command may be used:

```
# List the VMs and their current settings
Get-VM | Get-AdvancedSetting -Name "isolation.tools.copy.disable" | Select
Entity, Name, Value
```

Remediation:

To explicitly disable VM console copy operations, run the following PowerCLI command:

```
# Add the setting to all VMs
Get-VM | New-AdvancedSetting -Name "isolation.tools.copy.disable" -value
$true
```

Default Value:

Disabled

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-367D02C1-B71F-4AC3-AA05-85033136A667.html>
2. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-52188148-C579-4F6A-8335-CFBCE0DD2167.html>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

8.4.25 (L1) Ensure VM Console Drag and Drop operations is disabled (Scored)

Profile Applicability:

- Level 1

Description:

VM console drag and drop operations should be disabled.

Rationale:

VM console drag and drop operations are disabled by default (not explicitly specified); however, explicitly disabling this feature enables audit controls to check that this setting is correct.

Audit:

To verify that VM console drag and drop operations are disabled, verify that `isolation.tools.dnd.disable` is missing or set to `TRUE`.

Alternately, the following PowerCLI command may be used:

```
# List the VMs and their current settings
Get-VM | Get-AdvancedSetting -Name "isolation.tools.dnd.disable" | Select
Entity, Name, Value
```

Remediation:

To explicitly disable VM console drag and drop operations, run the following PowerCLI command:

```
# Add the setting to all VMs
Get-VM | New-AdvancedSetting -Name "isolation.tools.dnd.disable" -value $true
```

Default Value:

Disabled

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-52188148-C579-4F6A-8335-CFBCE0DD2167.html>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

8.4.26 (L1) Ensure VM Console GUI Options is disabled (Scored)

Profile Applicability:

- Level 1

Description:

VM console and paste GUI options should be disabled.

Rationale:

VM console and paste GUI options are disabled by default (not explicitly specified); however, explicitly disabling this feature enables audit controls to check that this setting is correct.

Audit:

To verify that VM console and paste GUI options are disabled, verify that `isolation.tools.setGUIOptions.enable` option is missing or set to `FALSE`. Alternately, the following PowerCLI command may be used:

```
# List the VMs and their current settings
Get-VM | Get-AdvancedSetting -Name "isolation.tools.setGUIOptions.enable" |
Select Entity, Name, Value
```

Remediation:

To explicitly disable VM console and paste GUI options, run the following PowerCLI command:

```
# Add the setting to all VMs
Get-VM | New-AdvancedSetting -Name "isolation.tools.setGUIOptions.enable" -
value $false
```

Default Value:

Disabled

References:

1. <https://docs.vmware.com/en/VMware-Tools/10.3.0/com.vmware.vsphere.vmwaretools.doc/GUID-685722FA-9009-439C-9142-18A9E7C592EA.html?hWord=N4IghgNiBcIMoFMDGBXATgSwC4E8AEAwgPYB2AzhgCYJphYall4BmRahpzGA5uhidzwA1ALIB3MGgR4AKkSIQyIAL5A>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

8.4.27 (L1) Ensure VM Console Paste operations are disabled (Scored)

Profile Applicability:

- Level 1

Description:

VM console paste operations should be disabled.

Rationale:

VM console paste operations are disabled by default (not explicitly specified); however, explicitly disabling this feature enables audit controls to check that this setting is correct.

Audit:

To verify that VM console paste operations are disabled, verify that

`isolation.tools.paste.disable` is missing or set to `TRUE`.

Alternately, the following PowerCLI command may be used:

```
# List the VMs and their current settings
Get-VM | Get-AdvancedSetting -Name "isolation.tools.paste.disable" | Select
Entity, Name, Value
```

Remediation:

To explicitly disable VM console paste operations, run the following PowerCLI command:

```
# Add the setting to all VMs
Get-VM | New-AdvancedSetting -Name "isolation.tools.paste.disable" -value
$true
```

Default Value:

Disabled

References:

1. <https://docs.vmware.com/en/VMware-Tools/10.3.0/com.vmware.vsphere.vmwaretools.doc/GUID-685722FA-9009-439C-9142-18A9E7C592EA.html?hWord=N4IghgNiBcIMoFMDGBXATgSwC4E8AEAwgPYB2AzhgCYJphYall4BmRahpzGA5uhidzwA1ALIB3MGgR4AKkSIQyIAL5A>

2. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-367D02C1-B71F-4AC3-AA05-85033136A667.html>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

8.4.28 (L1) Ensure access to VM console via VNC protocol is limited (Scored)

Profile Applicability:

- Level 1

Description:

Minimize access to the Virtual Machine via VNC protocol.

Rationale:

The VM console enables you to connect to the console of a virtual machine, in effect seeing what a monitor on a physical server would show. This console is also available via the VNC protocol. Setting up this access also involves setting up firewall rules on each ESXi server the virtual machine will run on.

Audit:

Check virtual machine configuration and verify that `RemoteDisplay.vnc.enabled` is missing or set to `FALSE`.

Additionally, the following PowerCLI command may be used:

```
# List the VMs and their current settings
Get-VM | Get-AdvancedSetting -Name "RemoteDisplay.vnc.enabled" | Select
Entity, Name, Value
```

Remediation:

To implement the recommended configuration state, run the following PowerCLI command:

```
# Add the setting to all VMs
Get-VM | New-AdvancedSetting -Name "RemoteDisplay.vnc.enabled" -value $false
```

Impact:

Configuring VM settings and opening up the firewall means multiple steps to be configured and monitored.

References:

1. https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.vm_admin.doc/GUID-BB1F20D3-339F-46F3-B020-D19C9322C001.html

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

8.4.29 (L2) Ensure all but VGA mode on virtual machines is disabled (Not Scored)

Profile Applicability:

- Level 2

Description:

Enable VGA Only mode for the Virtual Machine video card.

Note: this setting should only be applied to those virtual machines for which a video card is not needed such as Windows Server Core and UNIX / Linux servers.

Rationale:

Many Server-class virtual machines need only a standard VGA console (typically a Unix/Linux server or Windows Server Core system). Enabling this setting removes additional unnecessary graphics functionality beyond disabling 3D. This reduces the potential attack surface available for malicious attacks.

Audit:

Check that the virtual machine advanced setting of "svga.vgaonly" is set to TRUE. Additionally, the following PowerCLI command may be used:

```
# List the VMs and their current settings
Get-VM | Get-AdvancedSetting -Name "svga.vgaOnly" | Select Entity, Name, Value
```

Remediation:

Check that the virtual machine advanced setting of "svga.vgaonly" is set to TRUE.

To modify the advanced settings of a virtual machine using the vSphere Client:

1. Ensure that the virtual machine has been shutdown and is powered off.
2. Right-click on the virtual machine.
3. Click Edit Settings... to open the Virtual Machine Properties window.
4. Click the VM Options tab.
5. From the list on the left, click Advanced.
6. On the Configuration Parameters frame on the right, click Edit Configuration ...
7. Click Add Parameter.
8. On the new row, click under the Key column and specify the configuration option name.
9. On the new row, click under the Value column and specify the configuration value.

10. Start the virtual machine for the settings take effect.

Additionally, the following PowerCLI command may be used:

```
# Add the setting to all VMs
Get-VM | New-AdvancedSetting -Name "svga.vgaOnly" -value $true
```

Impact:

Configuring this setting to True will not allow any advanced graphics functions to work. Only character-cell console mode will be available. Use of this setting renders mks.enable3d moot. The mks.enable3d has no effect.

Note: this setting should only be applied to those virtual machines for which a video card is not needed such as Windows Server Core and UNIX / Linux servers.

Default Value:

The prescribed state is not the default state.

References:

1. <http://pubs.vmware.com/vsphere-60/topic/com.vmware.wssdk.apiref.doc/vim.option.OptionValue.html>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

8.5 Resources

8.5.1 (L2) Ensure VM limits are configured correctly (Not Scored)

Profile Applicability:

- Level 2

Description:

By default, all virtual machines on an ESXi host share the resources equally. By using the resource management capabilities of ESXi, such as limits with reservations, shares, and/or resource pools, you can control the server resources a virtual machine consumes.

Rationale:

Without resource management, one virtual machine could consume so much of the host's resources that other virtual machines on the same host could not perform their intended functions.

Audit:

To verify VM limits are configured correctly, confirm that limits with reservations, shares, and/or resource pools are in place to guarantee resources to critical VMs and to constrain resource consumption by VMs that have a greater risk of being exploited or attacked, or that run applications that are known to have the potential to greatly consume resources. The following PowerCLI command may be used to list resource configurations:

```
# List all Resource shares on all VMs  
Get-VM | Get-VMResourceConfiguration
```

Remediation:

To configure VM limits correctly, do all of the following that are applicable:

1. Use shares or reservations to guarantee resources to critical VMs.
2. Use limits to constrain resource consumption by VMs that have a greater risk of being exploited or attacked, or that run applications that are known to have the potential to greatly consume resources.
3. Use resource pools to guarantee resources to a common group of critical VMs.

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-E6262360-9300-4E10-ADE0-D4BED08DB5CA.html>

8.5.2 (L2) Ensure hardware-based 3D acceleration is disabled (Scored)

Profile Applicability:

- Level 2

Description:

Due to performance reasons, modern graphic rendering is done within a dedicated graphic processing unit (GPU). Virtual machines can use the host-based GPU for such operations as well. Such dedicated hardware is typically accessed by using complex APIs like OpenGL and DirectX. This hardware-based 3D acceleration should be disabled if it is not needed.

Rationale:

Security flaws within APIs can lead to serious security breaches like memory corruption, denial of service, and remote code execution.

Audit:

To verify that hardware-based 3D acceleration is disabled, check the virtual machine configuration file and verify that `mks.enable3d` is set to `FALSE`.

Alternately, the following PowerCLI command may be used:

```
# List the VMs and their current settings
Get-VM | Get-AdvancedSetting -Name "mks.enable3d" | Select Entity, Name, Value
```

Remediation:

To disable hardware-based 3D acceleration, run the following PowerCLI command:

```
# Add the setting to all VMs
Get-VM | New-AdvancedSetting -Name "mks.enable3d" -value $false
```

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-15D965F3-05E3-4E59-9F08-B305FDE672DD.html>

CIS Controls:

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

8.6 Storage

8.6.1 (L1) Ensure nonpersistent disks are limited (Scored)

Profile Applicability:

- Level 2

Description:

By default, VM disks use dependent mode, which means they are affected by snapshots. To avoid this, VM disks can use independent mode instead. Independent mode can be configured as persistent (data is written permanently to the disk) or nonpersistent (all changes made to disk are lost when the system is rebooted). Use of nonpersistent mode should be avoided unless the data is not needed (e.g., already duplicated elsewhere).

Rationale:

From a security standpoint, nonpersistent mode allows successful attackers to remove evidence of their actions or even their presence within a VM by performing a simple shutdown or reboot.

Audit:

To verify nonpersistent mode use is limited, review VM disk types to confirm that nonpersistent mode is only used when the loss of all stored data is not a concern. For all disks where nonpersistent mode is not to be used, `scsiX:Y.mode` should either be absent or be set to a value other than independent nonpersistent.

Alternately, the following PowerCLI command may be used to review the disk types:

```
#List the VM's and their disk types
Get-VM | Get-HardDisk | Select Parent, Name, Filename, DiskType, Persistence
```

Remediation:

To limit the use of nonpersistent mode, run the following PowerCLI command:

```
#Add the parameters for the following cmdlet to set the VM Disk Type:
Get-VM | Get-HardDisk | Set-HardDisk
```

References:

1. <https://code.vmware.com/apis/196/vsphere#/doc/vim.vm.device.VirtualDiskOptions.DiskMode.html>

2. <http://pubs.vmware.com/vsphere-60/topic/com.vmware.vsphere.hostclient.doc/GUID-81629CAB-72FA-42F0-9F86-F8FD0DE39E57.html>

8.6.2 (L1) Ensure virtual disk shrinking is disabled (Scored)

Profile Applicability:

- Level 1

Description:

If Virtual disk shrinking is done repeatedly it will cause the virtual disk to become unavailable resulting in a denial of service. You can prevent virtual disk shrinking by disabling it.

Rationale:

Shrinking a virtual disk reclaims unused space in it. If there is empty space in the disk, this process reduces the amount of space the virtual disk occupies on the host drive. Normal users and processes—that is, users and processes without root or administrator privileges—within virtual machines have the capability to invoke this procedure. However, if this is done repeatedly, the virtual disk can become unavailable while this shrinking is being performed, effectively causing a denial of service. In most datacenter environments, disk shrinking is not done, so you should disable this feature. Repeated disk shrinking can make a virtual disk unavailable. This capability is available to nonadministrative users in the guest.

Audit:

Check virtual machine configuration file and verify that

`isolation.tools.diskShrink.disable` is set to `TRUE`.

Additionally, the following PowerCLI command may be used:

```
# List the VMs and their current settings
Get-VM | Get-AdvancedSetting -Name "isolation.tools.diskShrink.disable" |
Select Entity, Name, Value
```

Remediation:

To implement the recommended configuration state, run the following PowerCLI command:

```
# Add the setting to all VMs
Get-VM | New-AdvancedSetting -Name "isolation.tools.diskShrink.disable" -
value $true
```

Impact:

Inability to shrink virtual machine disks in the event that a datastore runs out of space.

Default Value:

The prescribed state is not the default state.

References:

1. <https://docs.vmware.com/en/VMware-Tools/10.3.0/com.vmware.vsphere.vmwaretools.doc/GUID-685722FA-9009-439C-9142-18A9E7C592EA.html?hWord=N4IghgNiBcIMoFMDGBXATgSwC4E8AEAwgPYB2AzhgCYJphYall4BmRahpzGA5uhidzwA1ALIB3MGgR4AKkSIQyIAL5A>
2. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-9610FE65-3A78-4982-8C28-5B34FEB264B6.html>

8.6.3 (L1) Ensure virtual disk wiping is disabled (Scored)

Profile Applicability:

- Level 1

Description:

Wiping a virtual disk reclaims all unused space in it. If there is empty space in the disk, this process reduces the amount of space the virtual disk occupies on the host drive. If virtual disk wiping is done repeatedly, it can cause the virtual disk to become unavailable while wiping occurs. In most datacenter environments, disk wiping is not needed, but normal users and processes--without administrative privileges--can issue disk wipes unless the feature is disabled.

Rationale:

Virtual disk wiping can effectively cause a denial of service.

Audit:

To verify that virtual disk wiping is disabled, check the virtual machine configuration file and verify that `isolation.tools.diskWiper.disable` is set to TRUE.

Alternately, the following PowerCLI command may be used:

```
# List the VMs and their current settings
Get-VM | Get-AdvancedSetting -Name "isolation.tools.diskWiper.disable" |
Select Entity, Name, Value
```

Remediation:

To disable virtual disk wiping, run the following PowerCLI command:

```
# Add the setting to all VMs
Get-VM | New-AdvancedSetting -Name "isolation.tools.diskWiper.disable" -value
$true
```

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-9610FE65-3A78-4982-8C28-5B34FEB264B6.html>
2. <https://docs.vmware.com/en/VMware-Tools/10.3.0/com.vmware.vsphere.vmwaretools.doc/GUID-685722FA-9009-439C-9142-18A9E7C592EA.html>

8.7 Tools

8.7.1 (L2) Ensure VIX messages from the VM are disabled (Scored)

Profile Applicability:

- Level 2

Description:

The VIX API is a library for writing scripts and programs to manipulate virtual machines. If you do not make use of custom VIX programming in your environment, then you should disable certain features, such as the ability to send messages from the VM to the host. Disabling that feature does not adversely affect the functioning of VIX operations that originate outside the guest, so certain VMware and third-party solutions that rely upon this capability should continue to work. This is a deprecated interface.

Rationale:

Disabling unneeded features reduces the potential for vulnerabilities.

Audit:

To verify VIX messages from the VM are disabled, check the VM configuration file and verify that `isolation.tools.vixMessage.disable` is set to `TRUE`.

Alternately, the following PowerCLI command may be used:

```
# List the VMs and their current settings
Get-VM | Get-AdvancedSetting -Name "isolation.tools.vixMessage.disable" |
Select Entity, Name, Value
```

Remediation:

To disable VIX messages from the VM, run the following PowerCLI command:

```
# Add the setting to all VMs
Get-VM | New-AdvancedSetting -Name "isolation.tools.vixMessage.disable" -
value $true
```

References:

1. <https://pubs.vmware.com/vsphere-6-5/index.jsp?topic=%2Fcom.vmware.vddk.pg.doc%2FvddkTasks.8.8.html>

8.7.2 (L1) Ensure the number of VM log files is configured properly (Scored)

Profile Applicability:

- Level 1

Description:

Normally a new log file is created only when a host is rebooted, so the file can grow to be quite large. You can ensure that new log files are created more frequently by limiting the maximum size of the log files. If you want to restrict the total size of logging data, VMware recommends saving 10 log files, each one limited to 1 MB. Each time an entry is written to the log, the size of the log is checked; if it is over the limit, the next entry is written to a new log. If the maximum number of log files already exists, when a new one is created, the oldest log file is deleted.

Rationale:

Log files should be rotated to preserve log data in case of corruption or destruction of the current log file, and to avoid the likelihood of logging issues caused by an overly large log file.

Audit:

To verify that log files will be created more frequently, check the virtual machine configuration file and verify that `log.keepOld` is set to 10.

Alternately, the following PowerCLI command may be used:

```
# List the VMs and their current settings
Get-VM | Get-AdvancedSetting -Name "log.keepOld" | Select Entity, Name, Value
```

Remediation:

To set the number of log files to be used to 10, run the following PowerCLI command:

```
# Add the setting to all VMs
Get-VM | New-AdvancedSetting -Name "log.keepOld" -value "10"
```

Impact:

A more extreme strategy is to disable logging altogether for the virtual machine. Disabling logging makes troubleshooting challenging and support difficult. Do not consider disabling logging unless the log file rotation approach proves insufficient.

References:

1. <https://docs.vmware.com/en/VMware-Tools/10.3.0/com.vmware.vsphere.vmwaretools.doc/GUID-685722FA-9009-439C-9142-18A9E7C592EA.html>

CIS Controls:

Version 7

6.4 Ensure adequate storage for logs

Ensure that all systems that store logs have adequate storage space for the logs generated.

8.7.3 (L2) Ensure host information is not sent to guests (Scored)

Profile Applicability:

- Level 2

Description:

Configure VMware Tools to disable host information from being sent to guests unless a particular VM requires this information for performance monitoring purposes.

Rationale:

By enabling a VM to get detailed information about the physical host, an adversary could potentially use this information to inform further attacks on the host.

Audit:

To verify host information is not sent to guests, check the virtual machine configuration file and verify that `tools.guestlib.enableHostInfo` is set to `FALSE`.

Alternately, the following PowerCLI command may be used:

```
# List the VMs and their current settings
Get-VM | Get-AdvancedSetting -Name "tools.guestlib.enableHostInfo" | Select
Entity, Name, Value
```

Remediation:

To prevent host information from being sent to guests, run the following PowerCLI command:

```
# Add the setting to all VMs
Get-VM | New-AdvancedSetting -Name "tools.guestlib.enableHostInfo" -value
$false
```

Default Value:

FALSE

References:

1. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.security.doc/GUID-2CF880DA-2435-4201-9AFB-A16A11951A2D.html>

8.7.4 (L1) Ensure VM log file size is limited (Scored)

Profile Applicability:

- Level 1

Description:

Normally a new log file is created only when a host is rebooted, so the file can grow to be quite large. You can ensure that new log files are created more frequently by limiting the maximum size of the log files. If you want to restrict the total size of logging data, VMware recommends saving 10 log files, each one limited to 1 MB. If the maximum number of log files already exists, when a new one is created, the oldest log file is deleted.

Rationale:

Virtual machine users and processes can abuse logging either on purpose or inadvertently so that large amounts of data flood the log file. Without restrictions on maximum log file size, over time a log file can consume enough file system space to cause a denial of service.

Audit:

To verify the maximum log file size is limited properly, check the virtual machine configuration file and confirm that `log.rotateSize` is set to 1024000.

Alternately, the following PowerCLI command may be used:

```
# List the VMs and their current settings
Get-VM | Get-AdvancedSetting -Name "log.rotateSize" | Select Entity, Name, Value
```

Remediation:

To properly limit the maximum log file size, run the following PowerCLI command:

```
# Add the setting to all VMs
Get-VM | New-AdvancedSetting -Name "log.rotateSize" -value "1024000"
```

Impact:

A more extreme strategy is to disable logging altogether for the virtual machine. Disabling logging makes troubleshooting challenging and support difficult. Do not consider disabling logging unless the log file rotation approach proves insufficient.

References:

1. <http://kb.vmware.com/kb/8182749>
2. <https://docs.vmware.com/en/VMware-vSphere/6.5/com.vmware.vsphere.monitoring.doc/GUID-2DD66869-52C7-42C5-8F5B-145EBD26BBA1.html>

CIS Controls:

Version 7

6.4 Ensure adequate storage for logs

Ensure that all systems that store logs have adequate storage space for the logs generated.

Appendix: Summary Table

Control		Set Correctly	
		Yes	No
1	Install		
1.1	(L1) Ensure ESXi is properly patched (Scored)	☐	☐
1.2	(L1) Ensure the Image Profile VIB acceptance level is configured properly (Scored)	☐	☐
1.3	(L1) Ensure no unauthorized kernel modules are loaded on the host (Scored)	☐	☐
2	Communication		
2.1	(L1) Ensure NTP time synchronization is configured properly (Scored)	☐	☐
2.2	(L1) Ensure the ESXi host firewall is configured to restrict access to services running on the host (Scored)	☐	☐
2.3	(L1) Ensure Managed Object Browser (MOB) is disabled (Scored)	☐	☐
2.4	(L1) Ensure default self-signed certificate for ESXi communication is not used (Scored)	☐	☐
2.5	(L1) Ensure SNMP is configured properly (Not Scored)	☐	☐
2.6	(L1) Ensure dvfilter API is not configured if not used (Scored)	☐	☐
2.7	(L1) Ensure expired and revoked SSL certificates are removed from the ESXi server (Not Scored)	☐	☐
3	Logging		
3.1	(L1) Ensure a centralized location is configured to collect ESXi host core dumps (Scored)	☐	☐
3.2	(L1) Ensure persistent logging is configured for all ESXi hosts (Scored)	☐	☐
3.3	(L1) Ensure remote logging is configured for ESXi hosts (Scored)	☐	☐
4	Access		
4.1	(L1) Ensure a non-root user account exists for local admin access (Scored)	☐	☐
4.2	(L1) Ensure passwords are required to be complex (Scored)	☐	☐
4.3	(L1) Ensure Active Directory is used for local user authentication (Scored)	☐	☐
4.4	(L1) Ensure only authorized users and groups belong to the esxAdminsGroup group (Not Scored)	☐	☐
4.5	(L1) Ensure the Exception Users list is properly configured (Scored)	☐	☐
4.6	(L1) Ensure the maximum failed login attempts is set to 3 (Scored)	☐	☐

4.7	(L1) Ensure account lockout is set to 15 minutes (Scored)	☐	☐
5	Console		
5.1	(L1) Ensure the DCUI timeout is set to 600 seconds or less (Scored)	☐	☐
5.2	(L2) Ensure DCUI is disabled (Scored)	☐	☐
5.3	(L1) Ensure the ESXi shell is disabled (Scored)	☐	☐
5.4	(L1) Ensure SSH is disabled (Scored)	☐	☐
5.5	(L1) Ensure CIM access is limited (Not Scored)	☐	☐
5.6	(L1) Ensure Lockdown mode is enabled (Scored)	☐	☐
5.7	(L2) Ensure the SSH authorized_keys file is empty (Scored)	☐	☐
5.8	(L1) Ensure idle ESXi shell and SSH sessions time out after 300 seconds or less (Scored)	☐	☐
5.9	(L1) Ensure the shell services timeout is set to 1 hour or less (Scored)	☐	☐
5.10	(L1) Ensure DCUI has a trusted users list for lockdown mode (Not Scored)	☐	☐
5.11	(L2) Ensure contents of exposed configuration files have not been modified (Not Scored)	☐	☐
6	Storage		
6.1	(L1) Ensure bidirectional CHAP authentication for iSCSI traffic is enabled (Scored)	☐	☐
6.2	(L1) Ensure the uniqueness of CHAP authentication secrets for iSCSI traffic (Not Scored)	☐	☐
6.3	(L1) Ensure storage area network (SAN) resources are segregated properly (Not Scored)	☐	☐
6.4	(L2) Ensure VMDK files are zeroed out prior to deletion (Not Scored)	☐	☐
7	vNetwork		
7.1	(L1) Ensure the vSwitch Forged Transmits policy is set to reject (Scored)	☐	☐
7.2	(L1) Ensure the vSwitch MAC Address Change policy is set to reject (Scored)	☐	☐
7.3	(L1) Ensure the vSwitch Promiscuous Mode policy is set to reject (Scored)	☐	☐
7.4	(L1) Ensure port groups are not configured to the value of the native VLAN (Scored)	☐	☐
7.5	(L1) Ensure port groups are not configured to VLAN values reserved by upstream physical switches (Not Scored)	☐	☐
7.6	(L1) Ensure port groups are not configured to VLAN 4095 except for Virtual Guest Tagging (VGT) (Scored)	☐	☐
8	Virtual Machines		
8.1	Communication		
8.1.1	(L1) Ensure informational messages from the VM to the VMX	☐	☐

	file are limited (Scored)		
8.1.2	(L2) Ensure only one remote console connection is permitted to a VM at any time (Scored)	☐	☐
8.2	Devices		
8.2.1	(L1) Ensure unnecessary floppy devices are disconnected (Scored)	☐	☐
8.2.2	(L2) Ensure unnecessary CD/DVD devices are disconnected (Scored)	☐	☐
8.2.3	(L1) Ensure unnecessary parallel ports are disconnected (Scored)	☐	☐
8.2.4	(L1) Ensure unnecessary serial ports are disconnected (Scored)	☐	☐
8.2.5	(L1) Ensure unnecessary USB devices are disconnected (Scored)	☐	☐
8.2.6	(L1) Ensure unauthorized modification and disconnection of devices is disabled (Scored)	☐	☐
8.2.7	(L1) Ensure unauthorized connection of devices is disabled (Scored)	☐	☐
8.3	Guest		
8.3.1	(L1) Ensure unnecessary or superfluous functions inside VMs are disabled (Not Scored)	☐	☐
8.3.2	(L1) Ensure use of the VM console is limited (Not Scored)	☐	☐
8.3.3	(L1) Ensure secure protocols are used for virtual serial port access (Not Scored)	☐	☐
8.3.4	(L1) Ensure templates are used whenever possible to deploy VMs (Not Scored)	☐	☐
8.4	Monitor		
8.4.1	(L1) Ensure access to VMs through the dvfilter network APIs is configured correctly (Not Scored)	☐	☐
8.4.2	(L1) Ensure VMsafe Agent Address is configured correctly (Not Scored)	☐	☐
8.4.3	(L1) Ensure VMsafe Agent Port is configured correctly (Not Scored)	☐	☐
8.4.4	(L1) Ensure VMsafe Agent is configured correctly (Not Scored)	☐	☐
8.4.5	(L2) Ensure Autologon is disabled (Scored)	☐	☐
8.4.6	(L2) Ensure BIOS BBS is disabled (Scored)	☐	☐
8.4.7	(L2) Ensure Guest Host Interaction Protocol Handler is set to disabled (Scored)	☐	☐
8.4.8	(L2) Ensure Unity Taskbar is disabled (Scored)	☐	☐
8.4.9	(L2) Ensure Unity Active is disabled (Scored)	☐	☐
8.4.10	(L2) Ensure Unity Window Contents is disabled (Scored)	☐	☐
8.4.11	(L2) Ensure Unity Push Update is disabled (Scored)	☐	☐

8.4.12	(L2) Ensure Drag and Drop Version Get is disabled (Scored)	☐	☐
8.4.13	(L2) Ensure Drag and Drop Version Set is disabled (Scored)	☐	☐
8.4.14	(L2) Ensure Shell Action is disabled (Scored)	☐	☐
8.4.15	(L2) Ensure Request Disk Topology is disabled (Scored)	☐	☐
8.4.16	(L2) Ensure Trash Folder State is disabled (Scored)	☐	☐
8.4.17	(L2) Ensure Guest Host Interaction Tray Icon is disabled (Scored)	☐	☐
8.4.18	(L2) Ensure Unity is disabled (Scored)	☐	☐
8.4.19	(L2) Ensure Unity Interlock is disabled (Scored)	☐	☐
8.4.20	(L2) Ensure GetCreds is disabled (Scored)	☐	☐
8.4.21	(L2) Ensure Host Guest File System Server is disabled (Scored)	☐	☐
8.4.22	(L2) Ensure Guest Host Interaction Launch Menu is disabled (Scored)	☐	☐
8.4.23	(L2) Ensure memSchedFakeSampleStats is disabled (Scored)	☐	☐
8.4.24	(L1) Ensure VM Console Copy operations are disabled (Scored)	☐	☐
8.4.25	(L1) Ensure VM Console Drag and Drop operations is disabled (Scored)	☐	☐
8.4.26	(L1) Ensure VM Console GUI Options is disabled (Scored)	☐	☐
8.4.27	(L1) Ensure VM Console Paste operations are disabled (Scored)	☐	☐
8.4.28	(L1) Ensure access to VM console via VNC protocol is limited (Scored)	☐	☐
8.4.29	(L2) Ensure all but VGA mode on virtual machines is disabled (Not Scored)	☐	☐
8.5	Resources		
8.5.1	(L2) Ensure VM limits are configured correctly (Not Scored)	☐	☐
8.5.2	(L2) Ensure hardware-based 3D acceleration is disabled (Scored)	☐	☐
8.6	Storage		
8.6.1	(L1) Ensure nonpersistent disks are limited (Scored)	☐	☐
8.6.2	(L1) Ensure virtual disk shrinking is disabled (Scored)	☐	☐
8.6.3	(L1) Ensure virtual disk wiping is disabled (Scored)	☐	☐
8.7	Tools		
8.7.1	(L2) Ensure VIX messages from the VM are disabled (Scored)	☐	☐
8.7.2	(L1) Ensure the number of VM log files is configured properly (Scored)	☐	☐
8.7.3	(L2) Ensure host information is not sent to guests (Scored)	☐	☐
8.7.4	(L1) Ensure VM log file size is limited (Scored)	☐	☐

Appendix: Change History

Date	Version	Changes for this version
11/14/2018	1.0.0	Initial Release